

Kernel Breach

Lesson plans and learning time

486 hours

of lessons, simulated labs and checkpoints across 6 paths, 96 modules

Cybersecurity Rookie

11 modules | 60 lessons | 45 labs

45h

Security Core

15 modules | 84 lessons | 62 labs

66h 50m

Cyber Analyst (SOC)

18 modules | 102 lessons | 75 labs

92h 20m

Penetration Testing

20 modules | 120 lessons | 86 labs

112h 10m

Security Engineering

18 modules | 107 lessons | 77 labs

97h 45m

AI Security

14 modules | 80 lessons | 57 labs

71h 50m

Order: Cybersecurity Rookie, then Security Core, then any specialization in any order.

How a module is built

Every module is compact: a short run of lessons, hands-on simulated labs, and a checkpoint. Depth comes from practice, not from long reading.

Lesson

15 min

Learn it at three depths (Simple, Analogy, Technical), watch it step by step, then answer about 8 questions.

Simulated lab

30 / 40 / 50 min

Hands-on in a realistic simulator: terminal, log viewer, packet viewer, mock SIEM, web proxy, code or config editor. Length grows with level (Beginner / Intermediate / Advanced). Each module has about 7 labs for every 10 lessons, at least 2.

Checkpoint

30 min

10 questions on the whole module. 80% to pass. Misses go into Refresh.

Path capstone

2 to 8 h

A multi-step simulated engagement or exam that ties the whole path together.

Refresh

ongoing

Spaced review sets itself from the confidence rating you give after each lesson. Not counted in the hours here.

Hours per path

Path	Lessons	Labs	Checkpoints	Capstone	Total
● Cybersecurity Rookie	15h	22h 30m	5h 30m	2h	45h
● Security Core	21h	35h 20m	7h 30m	3h	66h 50m
● Cyber Analyst (SOC)	25h 30m	51h 50m	9h	6h	92h 20m
● Penetration Testing	30h	64h 10m	10h	8h	112h 10m
● Security Engineering	26h 45m	56h	9h	6h	97h 45m
● AI Security	20h	39h 50m	7h	5h	71h 50m

Honest note: these hours are study and practice time inside the app. They get a learner close to the knowledge behind entry and intermediate certifications, but the app is a guide, not an official exam prep, and a phone simulator does not replace real lab time.

Cybersecurity Rookie

45h

Start from zero: how computers, networks, the web, Linux and Windows work, before touching security.

Best for: Complete beginners and career changers. No experience needed.

Needs: Nothing. This is the first path.

Certification link: Supports foundations for CompTIA ITF+ and Network+ topics (OSI, ports, DNS). Guide only, not an official prep.

CAPSTONE: Secure the Small Office Workstation (2h)

Multi-step simulated engagement: map the office network, harden a Linux and a Windows host, triage logs for a brute-force attempt, script a report and rank the risks.

STAGE 1: HOW COMPUTERS AND NETWORKS WORK

ROOK-01

Welcome to Cybersecurity

Beginner

4 lessons | 3 labs | 3h

- + Define cybersecurity and distinguish red, blue and purple team work
- + Match common job roles to their daily tasks
- + Apply basic legal and ethical rules to security testing

LESSONS (15 min each)

1 What Cybersecurity Is and Why It Matters

Define cybersecurity and explain its goals of protecting systems, data and people from misuse.

2 Red, Blue and Purple Teams, Job Roles

Contrast offensive, defensive and collaborative teams and map SOC, pentest and GRC roles.

3 Famous Breaches: Target, Equifax, SolarWinds

Explain root causes of three major breaches and the controls that would have limited each.

4 Ethics, the Law and How to Study

Describe authorization, scope, CFAA-style laws and responsible disclosure, and plan a study routine.

SIMULATED LABS

Sort the Job Roles

Scenario

Read six short job tasks and assign each to the correct role: SOC analyst, pentester, GRC, or incident responder.

Breach Timeline Triage

Log viewer

Review a breach timeline and mark the initial access, lateral movement and detection gap events.

Authorized or Not?

Chat sim

Answer client requests and decide which are in scope, need written authorization, or must be refused.

CHECKPOINT (30 min)

Team colors, role responsibilities, breach root causes, authorization and legal boundaries

ROOK-02

How Computers Work

Beginner

5 lessons | 4 labs | 3h 45m

- + Convert between binary, decimal, hex and ASCII
- + Identify the roles of CPU, RAM, storage and the OS kernel
- + Describe processes, file types and virtual machine isolation

LESSONS (15 min each)

1 CPU, RAM and Storage

Explain how the CPU, volatile RAM and persistent storage (HDD, SSD) cooperate to run a program.

2 Operating Systems and the Kernel

Describe kernel vs user space, drivers, system calls and the main OS families.

3 Binary, Hex and ASCII

Convert values between binary, decimal and hex and decode ASCII text by hand.

4 Files, Extensions and Processes

Explain file signatures (magic bytes), process vs program, PID, and parent-child relationships.

5 Virtual Machines and Hypervisors

Explain Type 1 vs Type 2 hypervisors, snapshots, and why VMs are used for safe analysis.

SIMULATED LABS

Binary and Hex Converter Drill

Scenario

Convert ten values among binary, decimal and hex, then decode a short ASCII string byte by byte.

Spot the Fake Extension

File explorer

Inspect file headers and identify which files have extensions that do not match their magic bytes.

Process Tree Walkthrough

Terminal

Run ps to list processes, find a parent PID, and identify the process that owns a given file.

Design a Safe Analysis Lab

Diagram

Place a VM, host-only network and snapshot on a canvas so malware samples cannot reach the host network.

CHECKPOINT (30 min)

Number bases, ASCII, hardware roles, process basics, hypervisor types and VM isolation

ROOK-03

Networking Fundamentals

Beginner

8 lessons | 6 labs | 5h 30m

- + Calculate subnets and distinguish IP from MAC addressing
- + Trace a packet through the OSI and TCP/IP layers
- + Troubleshoot connectivity using ping, traceroute and DNS tools

LESSONS (15 min each)

1 IPv4, IPv6 and MAC Addresses

Read IPv4 and IPv6 addresses, private ranges (RFC 1918) and MAC addresses with OUI prefixes.

2 Subnet Masks and CIDR

Calculate network, broadcast and host range for a CIDR block such as 192.168.1.0/26.

3 OSI and TCP/IP Models

Map protocols and devices to the seven OSI layers and the four TCP/IP layers.

4 TCP vs UDP and the Three-Way Handshake

Explain SYN, SYN-ACK, ACK, flags, reliability and when UDP is chosen over TCP.

5 Ports and Common Services

Recall well-known ports (22, 53, 80, 443, 3389) and explain sockets and listening states.

6 DNS, DHCP and NAT

Describe DNS record types, the DHCP DORA exchange and how NAT/PAT shares one public IP.

7 Routers, Switches and Wi-Fi

Explain switch CAM tables, router tables, VLAN basics, and Wi-Fi standards, SSIDs and WPA2/WPA3.

8 ping, traceroute, nslookup and ARP

Use ICMP tools to locate a fault and read TTL, hop latency and ARP cache output.

SIMULATED LABS

Subnet Calculator Practice

Scenario

Given six CIDR blocks, enter network address, broadcast address and usable host count.

Read the Handshake

Packet viewer

Open a capture and label the SYN, SYN-ACK and ACK packets, then find the server port.

Layer the Packet

Diagram

Drag headers into place to build an Ethernet, IP, TCP and HTTP frame in the correct order.

DNS Lookup Troubleshoot

Terminal

Run nslookup and dig for A, MX and NS records and find why one hostname fails to resolve.

DHCP Lease Debug

Log viewer

Read DHCP logs to find a client stuck on a 169.254.x.x address and identify the missing step.

Where Does the Packet Die?

Terminal

Run ping and traceroute on a simulated network and locate the hop that drops traffic.

CHECKPOINT (30 min)

Subnetting, OSI layers, TCP vs UDP, common ports, DNS/DHCP/NAT roles, ICMP tool output

STAGE 2: THE WEB AND YOUR FIRST OPERATING SYSTEM

ROOK-04

How the Web Works

Beginner

6 lessons | 4 labs | 4h

- + Break down a URL and read an HTTP request and response
- + Explain cookies, sessions and the front-end stack
- + Write basic SQL SELECT queries and read JSON from an API

LESSONS (15 min each)

1 URLs and the Request Lifecycle

Parse a URL into scheme, host, port, path, query and fragment and trace a page load through DNS and TCP.

2 HTTP Methods, Headers and Status Codes

Interpret GET, POST, PUT, DELETE, key headers and 2xx, 3xx, 4xx and 5xx status codes.

3 Cookies, Sessions and HTTPS

Explain Set-Cookie flags (HttpOnly, Secure, SameSite), session IDs and TLS in transit.

4 HTML, CSS and JavaScript Basics

Describe the DOM, how forms submit data and what client-side JavaScript can and cannot be trusted with.

5 APIs, REST and JSON

Read a REST endpoint, a JSON body and an API key or bearer token header.

6 Databases and SQL Basics

Write SELECT, WHERE, INSERT and JOIN statements and explain why user input must be parameterized.

SIMULATED LABS

Inspect a Request

Web proxy

Intercept a login request in the proxy and identify the method, headers, cookie and body parameters.

Status Code Detective

Log viewer

Read web server logs and explain what each 301, 403, 404 and 500 line means for the user.

Cookie Flag Audit

Web proxy

Check three responses and note which cookies miss HttpOnly, Secure or SameSite.

Query the Customers Table

Terminal

Run SELECT queries with WHERE and ORDER BY on a sample database to answer four lookup questions.

CHECKPOINT (30 min)

HTTP anatomy, status codes, cookie attributes, DOM and JS basics, JSON, SQL SELECT syntax

ROOK-05

Linux I: Meet the Terminal

Beginner

5 lessons | 4 labs | 3h 45m

- + Navigate the Linux file system with `pwd`, `ls` and `cd`
- + Use absolute and relative paths correctly
- + Look up command options with `man` and `--help`

LESSONS (15 min each)

1 What Linux Is: Kernel, Distros, Shells

Explain the Linux kernel, distributions such as Debian and Ubuntu, and bash as a shell.

2 The Prompt and Command Anatomy

Read a prompt and break a command into program, options and arguments.

3 `pwd`, `ls` and `cd`

Move around and list directories using `ls -l`, `-a` and `-h` and `cd` shortcuts like `~` and `-`.

4 The Filesystem Hierarchy and Paths

Distinguish absolute from relative paths and know `/etc`, `/var`, `/home`, `/tmp` and `/bin`.

5 `man` Pages and Getting Help

Search man pages, read the synopsis and flags, and use `--help` and `apropos`.

SIMULATED LABS

First Terminal Session

Terminal

Run `pwd`, `ls` and `cd` to reach a hidden project folder and report its full path.

Path Puzzle

Terminal

Reach five target directories using only relative paths, then repeat with absolute paths.

Find Where Logs Live

File explorer

Browse `/var/log` and `/etc` in the explorer and match each file to its purpose.

Decode the Flags

Terminal

Use `man` to find which `ls` option sorts by time, shows sizes and lists hidden files, then run it.

CHECKPOINT (30 min)

Prompt anatomy, `pwd/ls/cd`, absolute vs relative paths, FHS directories, man usage

ROOK-06

Linux II: Files and Folders

Beginner

5 lessons | 4 labs | 3h 45m

- + Create, copy, move and delete files and directories safely
- + Read files with `cat`, `less`, `head` and `tail`
- + Locate files using wildcards and `find`

LESSONS (15 min each)

1 `mkdir` and `touch`

Create directories (`mkdir -p`) and empty files and understand timestamps.

2 `cp`, `mv` and `rm`

Copy, rename, move and delete with `-r` and `-i` flags and explain why `rm` has no recycle bin.

3 Reading Files: `cat`, `less`, `head`, `tail`

Choose the right viewer and follow a growing log with `tail -f`.

4 Wildcards and Globbing

Use `*`, `?` and `[a-z]` patterns to act on groups of files and predict what a glob matches.

5 Hidden Files and `find`

Find files by name, type, size and mtime with `find` and reveal dotfiles such as `.bashrc`.

SIMULATED LABS

Build a Project Tree

Terminal

Create a nested directory layout with `mkdir -p` and `touch`, then verify it with `ls -R`.

Safe Cleanup

Terminal

Copy and move report files, then delete only the `.tmp` files using wildcards and `rm -i`.

Follow the Log

Log viewer

Use `tail` and `head` on a simulated auth log to find the most recent failed login lines.

Hunt the Large File

Terminal

Use `find` with `-name`, `-size` and `-mtime` to locate a 50 MB file modified in the last day.

CHECKPOINT (30 min)

File manipulation commands, `rm` risks, viewer choice, glob patterns, find options

ROOK-07

Linux III: Users and Permissions

Beginner

5 lessons | 4 labs | 3h 45m

- + Interpret ls -l output and numeric permissions
- + Change ownership and modes with chown and chmod
- + Apply sudo and least privilege correctly

LESSONS (15 min each)

- 1 Users, Groups and /etc/passwd**
Read /etc/passwd, /etc/shadow and /etc/group and use id, whoami and groups.
- 2 Reading ls -l Output**
Decode the type bit, owner, group, others, links, size and date fields in ls -l.
- 3 chmod: Symbolic and Octal Modes**
Set permissions with u+x style and numeric modes such as 640 and 755.
- 4 chown, chgrp and Special Bits**
Change owners and groups and explain setuid, setgid and the sticky bit on /tmp.
- 5 sudo and Least Privilege**
Use sudo and sudoers safely, explain root risks and why 777 is a vulnerability.

SIMULATED LABS

Decode the Permissions

Scenario

Read ten ls -l lines and state who can read, write and execute each file.

Fix the Broken Script

Terminal

Apply chmod to make a script executable by its owner only and verify with ls -l.

Lock Down a Secrets File

Terminal

Use chown and chmod 600 so only the service account can read an API key file.

Audit sudoers and Accounts

Config editor

Review /etc/passwd and sudoers entries to find an extra UID 0 user and an unrestricted sudo rule.

CHECKPOINT (30 min)

Permission bits, octal math, chown/chmod usage, setuid risk, sudo and least privilege

ROOK-08

Linux IV: Pipes, Processes and Network

Beginner

5 lessons | 4 labs | 3h 45m

- + Search and transform text with grep, pipes and redirects
- + Inspect and stop processes with ps, top and kill
- + Check updates and network state with apt, ip, ping and ss

LESSONS (15 min each)

- 1 grep and Regular Patterns**
Search with grep -i, -r, -n and -v and combine simple patterns to filter logs.
- 2 Pipes and Redirects**
Chain commands with |, redirect with >, >> and 2>, and use sort, uniq -c and wc.
- 3 Processes: ps, top and kill**
List processes, read CPU and memory use and end them with kill, kill -9 and signals.
- 4 Package Management with apt**
Update and upgrade with apt, search and install packages and explain why patching reduces risk.
- 5 Network Checks: ip, ping and ss**
Read ip a and ip route, test reachability with ping, and list listening ports with ss -tulpn.

SIMULATED LABS

Failed Logins by IP

Terminal

Pipe grep, sort and uniq -c over an auth log to rank source IPs by failed attempts.

Runaway Process

Terminal

Use top and ps to find a process using 95 percent CPU and terminate it with the right signal.

Patch the Box

Terminal

Run apt update, list upgradable packages and install a security update for a vulnerable package.

Who Is Listening?

Terminal

Run ss -tulpn and flag the unexpected service listening on 0.0.0.0, then trace its PID.

CHECKPOINT (30 min)

grep options, pipes vs redirects, process signals, apt workflow, ip and ss output

STAGE 3: WINDOWS, SCRIPTING AND SECURITY BASICS

ROOK-09

Windows Fundamentals

Beginner

6 lessons | 4 labs | 4h

- + Navigate the Windows file system, registry and services
- + Use Task Manager, cmd and PowerShell for basic inspection
- + Explain UAC, Active Directory basics, Defender and the firewall

LESSONS (15 min each)

1 Windows File System and NTFS

Describe C:\Windows, Users, Program Files, NTFS permissions and alternate data streams.

2 Users, Groups and UAC

Explain local users, the Administrators group, SIDs and how UAC prompts limit elevation.

3 The Registry and Services

Navigate HKLM and HKCU hives, Run keys and the Services console, and note persistence locations.

4 Task Manager, cmd and PowerShell

Use tasklist, ipconfig, netstat and PowerShell cmdlets like Get-Process and Get-Service.

5 Active Directory Introduction

Explain domains, domain controllers, OUs, group policy and Kerberos login at a high level.

6 Windows Defender and Firewall

Configure Defender scans, real-time protection and inbound firewall rules for profiles.

SIMULATED LABS

Find the Autorun Entry

Config editor

Browse registry Run keys and flag the entry that launches an unknown executable at login.

PowerShell Inspection

Terminal

Run Get-Process, Get-Service and Get-LocalUser to list stopped services and unexpected local accounts.

Firewall Rule Fix

Config editor

Create an inbound rule that allows only RDP from one subnet and disable a risky open rule.

Active Directory Tree

Diagram

Build a domain with OUs, users and groups and attach a group policy to the correct OU.

CHECKPOINT (30 min)

Windows paths, UAC, registry persistence keys, PowerShell cmdlets, AD terms, firewall rules

ROOK-10

Scripting Basics

Beginner

6 lessons | 4 labs | 4h

- + Write Bash and Python scripts using variables, conditions and loops
- + Read files and extract data with regex
- + Automate small repetitive tasks with functions

LESSONS (15 min each)

1 Variables and Data Types

Declare variables in Bash and Python and use strings, integers, lists and dictionaries.

2 Conditions and Comparisons

Use if/elif/else, test operators and exit codes to branch in Bash and Python.

3 Loops

Iterate with for and while loops over lists, ranges and lines of a file.

4 Functions and Arguments

Define functions, pass arguments such as \$1 and sys.argv and return values.

5 Reading Files and Regex

Read files line by line and match IPs, emails and timestamps with regular expressions.

6 Automating a Small Task

Build a script that parses a log, counts events and writes a summary report.

SIMULATED LABS

Fix the Script

Code editor

Repair a Python script with a syntax error and a wrong comparison until it passes the tests.

Ping Sweep Loop

Code editor

Complete a Bash for loop that pings a host range and prints only the live addresses.

Regex IP Extractor

Code editor

Write a regex that extracts every IPv4 address from a sample log and count unique matches.

Log Summary Tool

Code editor

Finish a Python function that reads a log and prints the top five failed-login usernames.

CHECKPOINT (30 min)

Syntax of variables, conditions and loops, function arguments, file reading, regex basics

ROOK-11

Security Foundations

Beginner

5 lessons | 4 labs | 3h 45m

- + Apply the CIA triad to classify security failures
- + Rank risks using threat, vulnerability and impact
- + Choose layered controls and write basic policy statements

LESSONS (15 min each)

- 1

The CIA Triad and Beyond

Define confidentiality, integrity and availability and add authenticity and non-repudiation.
- 2

Threats, Vulnerabilities and Risk

Distinguish threat, vulnerability, exploit and risk and compute likelihood times impact.
- 3

Attack Surface and Threat Actors

Identify exposed entry points and describe actors from script kiddies to nation states.
- 4

Defense in Depth and Least Privilege

Layer preventive, detective and corrective controls and apply least privilege and separation of duties.
- 5

Security Policies and Frameworks

Explain policies, standards, procedures and frameworks like NIST CSF and ISO 27001.

SIMULATED LABS

- Classify the Incident**

Read eight incidents and label each as a confidentiality, integrity or availability failure.

Scenario
- Build a Risk Register**

Score five findings by likelihood and impact and sort them into a prioritized risk register.

Scenario
- Layer the Defenses**

Place firewall, EDR, MFA, backups and logging on a diagram to cover a given attack path.

Diagram
- Shrink the Attack Surface**

Review a server config, disable unneeded services and ports, and apply a minimal-privilege account.

Config editor
- CHECKPOINT (30 min)**

CIA classification, risk terms and scoring, attack surface, layered controls, policy vs standard

Security Core

66h 50m

The core of cybersecurity: principles, threats, cryptography, access control, web and network security, and a first look at defense and offense.

Best for: Anyone who finished Pre-Security, or IT people new to security.

Needs: Pre-Security (or pass the placement quiz).

Certification link: Guide only: covers CompTIA Security+ concept areas and builds a base for eJPT and BTL1, but it is not an official prep course.

CAPSTONE: Breach of a Small Company (3h)

Simulated engagement: scope the test, recon and exploit a web app, then switch to SOC and triage the logs, contain it, and report with CVSS and a NIST CSF mapping.

STAGE 1: CORE IDEAS

CORE-01

Principles and Frameworks

Beginner

6 lessons | 4 labs | 4h

- + Classify controls and scenarios by CIA triad property
- + Map an attack to kill chain stages and ATT&CK tactics
- + Compare NIST CSF, ISO 27001 and CIS Controls by purpose

LESSONS (15 min each)

- 1 CIA triad and its failure modes**
Explain confidentiality, integrity and availability and give an attack and a control for each.
- 2 AAA and non-repudiation**
Distinguish authentication, authorization, accounting and show how signatures and logs give non-repudiation.
- 3 Defense in depth and least privilege**
Layer preventive, detective and corrective controls and apply least privilege and separation of duties.
- 4 Zero trust fundamentals**
Describe never trust, always verify, microsegmentation and policy decision points per NIST SP 800-207.
- 5 Kill chain and MITRE ATT&CK**
Map intrusion activity to the seven Lockheed Martin kill chain stages and ATT&CK tactics and techniques.
- 6 NIST CSF, ISO 27001 and CIS Controls**
Compare the CSF functions, ISO 27001 ISMS and Annex A, and CIS Controls IG1-IG3 safeguards.

SIMULATED LABS

Tag scenarios by CIA property

Scenario

Read 8 incident snippets and tag which CIA property each one violated, then choose the matching control.

Map an intrusion to ATT&CK

Diagram

Place observed events onto kill chain stages and attach ATT&CK technique IDs such as T1566 and T1059.

Match controls to NIST CSF functions

Scenario

Sort 12 controls into Identify, Protect, Detect, Respond, Recover and flag the gaps in a sample program.

Review an access log for AAA gaps

Log viewer

Find unauthenticated requests, over-privileged accounts and missing accounting entries in a sample audit log.

CHECKPOINT (30 min)

CIA classification, AAA terms, kill chain and ATT&CK mapping, CSF functions vs ISO 27001 vs CIS

CORE-02

The Threat Landscape

Beginner

6 lessons | 4 labs | 4h

- + Differentiate threat actors by motive, capability and TTPs
- + Identify malware families from behavior and indicators
- + Explain how real incidents unfolded and which control would have stopped them

LESSONS (15 min each)

1 Threat actors and motives

Compare nation-state, criminal, hacktivist, insider and script-kiddie actors by resources and motivation.

2 Attack surface and common attack types

Describe brute force, credential stuffing, password spraying, supply chain and zero-day attack types.

3 Viruses, worms and trojans

Explain how viruses, worms and trojans propagate and how each is detected.

4 Ransomware and extortion

Describe the ransomware chain from initial access to encryption, double extortion and RaaS.

5 Spyware, RATs, botnets and C2

Explain keyloggers, RATs, botnet C2 channels and beaconing indicators.

6 Incident case studies

Analyze WannaCry, NotPetya, SolarWinds, Colonial Pipeline and Equifax for root cause and missed controls.

SIMULATED LABS

Classify malware samples

Scenario

Review 6 behavior reports (file changes, network calls, persistence) and label the malware family.

Spot C2 beaconing in packets

Packet viewer

Find periodic HTTP or DNS callbacks in a capture and identify the infected host and C2 domain.

Read a ransomware process tree

Log viewer

Trace Sysmon events from a phishing attachment to shadow copy deletion and encryption.

Build the case study timeline

Diagram

Order the SolarWinds or Equifax events on a timeline and mark where a control would break the chain.

CHECKPOINT (30 min)

Actor motives, malware family traits, attack types, root causes in case studies

CORE-03

Social Engineering and Phishing

Beginner

5 lessons | 4 labs | 3h 45m

- + Recognize phishing, smishing and vishing indicators
- + Analyze a suspicious email header and URL
- + Choose technical and human controls against social engineering

LESSONS (15 min each)

1 Social engineering principles

Explain authority, urgency, scarcity and trust as levers and the pretexting attack cycle.

2 Phishing, spear phishing and whaling

Identify mass, targeted and executive phishing and the credential harvesting and payload variants.

3 Smishing, vishing and QR phishing

Recognize SMS, voice and QR lure patterns, caller ID spoofing and MFA fatigue prompts.

4 Business email compromise

Describe BEC variants such as invoice fraud and CEO fraud and the verification steps that stop them.

5 Spotting fakes and defending

Inspect headers (SPF, DKIM, DMARC), lookalike domains, link hover and apply reporting and awareness controls.

SIMULATED LABS

Triage a phishing inbox

Scenario

Sort 10 emails into legitimate, phishing and BEC and name the strongest indicator in each.

Read email headers

Log viewer

Check Received chain, Return-Path and SPF, DKIM, DMARC results to prove a sender is spoofed.

Dissect a malicious URL

Web proxy

Decode a shortened and obfuscated link, spot the lookalike domain and the redirect chain in a sandbox.

Handle a vishing call

Chat sim

Respond to a caller requesting a password reset and choose verification steps that deny the attacker.

CHECKPOINT (30 min)

Phishing variants, header analysis, SPF/DKIM/DMARC, BEC verification controls

CORE-04

Cryptography Basics

Beginner

8 lessons | 6 labs | 5h 30m

- + Choose between encoding, encryption and hashing
- + Explain how keys, certificates and TLS protect a connection
- + Store passwords safely with salted slow hashes

LESSONS (15 min each)

1 Encoding vs encryption vs hashing

Distinguish Base64 encoding, reversible encryption and one-way hashing with a use case for each.

2 Symmetric encryption

Explain AES, block modes (ECB, CBC, GCM), IVs and why key distribution is the hard part.

3 Asymmetric encryption and key exchange

Describe RSA, ECC and Diffie-Hellman and how public and private keys solve key exchange.

4 Hashing, HMAC and salting

Compare MD5, SHA-1, SHA-256, explain collisions, HMAC and why salts defeat rainbow tables.

5 Digital signatures

Explain how signing with a private key gives integrity, authenticity and non-repudiation.

6 Certificates and PKI

Describe X.509 fields, CA chains, root stores, CSR, revocation (CRL, OCSP) and expiry.

7 The TLS 1.2 and 1.3 handshake

Walk through ClientHello, key exchange, certificate validation, forward secrecy and cipher suites.

8 Password storage and cracking

Compare bcrypt, scrypt, Argon2 and PBKDF2, and explain dictionary, brute force and pepper.

SIMULATED LABS

Decode, decrypt and hash

Terminal

Use base64, openssl enc and sha256sum on sample data and state which operation is reversible.

Spot weak crypto choices

Config editor

Fix a TLS config by removing SSLv3, RC4 and CBC suites and enabling TLS 1.3 with strong ciphers.

Verify a signed file

Terminal

Check a SHA-256 checksum and an openssl signature and detect a tampered download.

Inspect a certificate chain

File explorer

Open sample X.509 certs, find issuer, SAN and expiry, and spot the broken chain or hostname mismatch.

Read a TLS handshake

Packet viewer

Identify ClientHello, ServerHello, selected cipher and certificate frames in a capture.

Crack weak password hashes

Terminal

Run a wordlist against unsalted MD5 hashes in a sandbox, then show bcrypt resisting the same attack.

CHECKPOINT (30 min)

Encoding vs encryption vs hashing, symmetric vs asymmetric, PKI, TLS handshake, password storage

CORE-05

Authentication and Access Control

Beginner

6 lessons | 4 labs | 4h

- + Compare authentication factors and MFA methods
- + Trace SAML and OAuth/OIDC flows and their tokens
- + Design RBAC and ABAC rules and secure sessions

LESSONS (15 min each)

1 Passwords and password managers

Apply NIST SP 800-63B guidance on length, breach checks and the role of managers and passkeys.

2 MFA and biometrics

Compare TOTP, push, FIDO2/WebAuthn and biometrics, and explain MFA fatigue and SIM swap risks.

3 Single sign-on and Kerberos basics

Explain SSO, identity providers and the Kerberos ticket-granting flow at concept level.

4 SAML, OAuth 2.0 and OpenID Connect

Distinguish SAML assertions, OAuth access tokens and OIDC ID tokens and the authorization code flow.

5 RBAC, ABAC and access models

Compare DAC, MAC, RBAC and ABAC and apply least privilege and periodic access reviews.

6 Session management and JWTs

Secure session IDs, cookies, timeouts and JWT signature, expiry and audience validation.

SIMULATED LABS

Choose MFA for scenarios

Scenario

Select the right factor for 6 user groups and justify against phishing resistance and usability.

Decode a JWT and find flaws

Web proxy

Inspect a captured JWT, spot alg none or a missing exp claim and replay it in the sandbox.

Trace an OAuth authorization code flow

Diagram

Arrange redirects, code and token exchange steps and mark where state and PKCE protect the flow.

Build RBAC roles

Config editor

Edit a role matrix to enforce least privilege and remove a separation of duties conflict.

CHECKPOINT (30 min)

Factors and MFA, SAML vs OAuth vs OIDC, RBAC vs ABAC, session and token security

STAGE 2: DEFENDING SYSTEMS

CORE-06

Network Security

Beginner

7 lessons | 5 labs | 4h 45m

- + Configure firewall rules and segment a network
- + Distinguish IDS, IPS, proxy and VPN roles
- + Recognize and mitigate MITM, ARP spoofing and DoS

LESSONS (15 min each)

- 1 Firewalls and ACLs**
Write stateless and stateful rules, apply default deny and explain NGFW and WAF differences.
- 2 IDS, IPS and network monitoring**
Compare signature and anomaly detection, Snort and Suricata rules and NIDS vs HIDS placement.
- 3 Proxies, VPNs and tunneling**
Explain forward and reverse proxies, IPsec and WireGuard VPNs, split tunneling and TLS inspection.
- 4 Segmentation, VLANs and the DMZ**
Design zones, VLANs and a DMZ so that a compromised host cannot reach internal systems.
- 5 Wi-Fi security**
Compare WEP, WPA2, WPA3, PSK and 802.1X, and describe evil twin and deauthentication attacks.
- 6 MITM, ARP spoofing and DNS attacks**
Explain ARP cache poisoning, DNS spoofing, SSL stripping and defenses such as DAI and HSTS.
- 7 DoS, DDoS and secure protocols**
Explain SYN floods and amplification, their mitigations, and swap Telnet, FTP, HTTP for SSH, SFTP, HTTPS.

SIMULATED LABS

Write firewall rules

[Config editor](#)

Build an iptables or ACL ruleset that allows web traffic, blocks lateral movement and logs drops.

Design a DMZ network

[Diagram](#)

Place web, DB and admin hosts in zones and draw the allowed flows between them.

Detect ARP spoofing

[Packet viewer](#)

Find duplicate MAC to IP mappings and gratuitous ARP replies in a capture and name the attacker.

Tune a Suricata alert

[Log viewer](#)

Review IDS alerts, separate false positives and write a rule to catch a port scan.

Triage a SYN flood

[Mock SIEM](#)

Identify the flood from connection logs, find top sources and select the right mitigation.

CHECKPOINT (30 min)

Firewall rule logic, IDS vs IPS, segmentation, Wi-Fi standards, MITM and DoS defenses, secure protocols

CORE-07

Web Application Security

Intermediate

8 lessons | 6 labs | 6h 30m

- + Identify OWASP Top 10 flaws in requests and code
- + Exploit and fix SQL injection, XSS, IDOR and CSRF in a sandbox
- + Apply secure headers, cookie flags and input handling

LESSONS (15 min each)

- 1 HTTP basics and the OWASP Top 10**
Review request, response, methods and status codes and name the categories of the OWASP Top 10.
- 2 Injection: SQLi and command injection**
Explain how unsanitized input alters queries and fix with parameterized statements and validation.
- 3 Cross-site scripting**
Distinguish reflected, stored and DOM XSS and apply output encoding and Content Security Policy.
- 4 Broken authentication and session flaws**
Identify weak login, session fixation and credential stuffing weaknesses and their fixes.
- 5 Broken access control and IDOR**
Detect IDOR and missing function-level checks and enforce server-side authorization.
- 6 CSRF and SSRF**
Explain forged state-changing requests and server-side request forgery, with tokens and SameSite as defenses.
- 7 Misconfiguration and vulnerable components**
Find default credentials, verbose errors, directory listing and outdated libraries (SCA, SBOM).
- 8 Secure headers, cookies and testing**
Set HSTS, CSP, X-Content-Type-Options and Secure, HttpOnly, SameSite cookie flags and use Burp or ZAP.

SIMULATED LABS

Intercept and modify a request

[Web proxy](#)

Capture a login request in a proxy, change a parameter and observe the server response.

Exploit SQL injection safely

[Web proxy](#)

Use a quote and UNION payload against a sandbox app to extract a user table, then note the cause.

Fix an injectable query

[Code editor](#)

Replace string concatenation with a parameterized query and verify the payload no longer works.

Find stored XSS

[Web proxy](#)

Submit a payload to a sandbox comment box, confirm execution and apply output encoding.

Enumerate IDOR

[Web proxy](#)

Change an order ID in a sandbox API call to read another user's data, then add an ownership check.

Harden headers and cookies

[Config editor](#)

Add CSP, HSTS and cookie flags to a server config and re-scan for missing headers.

CHECKPOINT (30 min)

OWASP categories, SQLi and XSS mechanics and fixes, IDOR, CSRF, headers and cookie flags

CORE-08

Endpoint and OS Security

Beginner

5 lessons | 4 labs | 3h 45m

- + Apply a hardening baseline to a system
- + Explain how AV, EDR and allowlisting detect and block threats
- + Design a backup and encryption plan

LESSONS (15 min each)

1 System hardening basics

Apply CIS Benchmarks: remove unused services, enforce least privilege, secure defaults and baseline configs.

2 Patch management

Describe the patch cycle, test rings, emergency patches and risks of unsupported software.

3 Antivirus, EDR and application allowlisting

Compare signature, heuristic and behavior detection, EDR telemetry and AppLocker-style allowlists.

4 Disk encryption and mobile device security

Explain BitLocker, FileVault, LUKS, TPM, MDM, jailbreaking and mobile app permissions.

5 Backups and recovery

Apply the 3-2-1 rule, immutable and offline backups, RPO, RTO and restore testing against ransomware.

SIMULATED LABS

Harden a Linux server

Terminal

Run commands to disable unused services, fix file permissions and set SSH to key-only login.

Audit a Windows baseline

Config editor

Compare a policy export to a CIS baseline and correct failing settings such as SMBv1 and password length.

Triage an EDR detection

Mock SIEM

Review an EDR alert, inspect the process tree and decide to isolate the host or close as benign.

Plan backups for ransomware

Scenario

Choose backup types, locations and test schedule that meet given RPO and RTO after a ransomware event.

CHECKPOINT (30 min)

Hardening steps, patching, AV vs EDR, allowlisting, disk encryption, 3-2-1 backups

CORE-09

Vulnerability Management

Intermediate

5 lessons | 4 labs | 4h 25m

- + Distinguish vulnerability, exploit and risk
- + Read CVE, CWE and CVSS data and prioritize findings
- + Run a scan-to-remediation cycle and know bug bounty basics

LESSONS (15 min each)

1 Vulnerability, threat, exploit and risk

Define each term and relate them with risk = likelihood x impact.

2 CVE, CWE, NVD and exploit databases

Look up CVE IDs, CWE weakness classes, NVD records and Exploit-DB or CISA KEV entries.

3 CVSS scoring

Read a CVSS v3.1 vector (AV, AC, PR, UI, S, C, I, A) and compute the severity band.

4 Scanning and the patching process

Explain authenticated vs unauthenticated scans with Nessus or OpenVAS, false positives and remediation SLAs.

5 Prioritization and bug bounty overview

Prioritize with CVSS, KEV, EPSS and asset value, and describe disclosure and bug bounty programs.

SIMULATED LABS

Score a CVSS vector

Scenario

Set base metrics for 4 vulnerabilities and compare the resulting scores and severity.

Triage scanner output

File explorer

Review a scan report, remove false positives and group findings by host and fix.

Search CVE records

Terminal

Use searchsploit and a CVE lookup on a sandbox service banner to find known vulnerabilities.

Rank the remediation queue

Scenario

Order 8 findings using CVSS, KEV status and asset criticality and assign SLAs.

CHECKPOINT (30 min)

CVE vs CWE vs CVSS, vector reading, scanner types, prioritization logic, patch process

CORE-10

Defensive Security Intro

Intermediate

7 lessons | 5 labs | 5h 35m

- + Search and correlate logs in a SIEM
- + Triage alerts and escalate correctly
- + Follow incident response phases and preserve evidence

LESSONS (15 min each)

- 1 Logging and monitoring fundamentals**
Identify key log sources (Windows Event IDs, syslog, auth, proxy, DNS) and time sync and retention needs.
- 2 SIEM basics**
Explain log ingestion, normalization, correlation rules and search queries in Splunk or Elastic.
- 3 SOC roles and alert triage**
Describe Tier 1-3 roles and triage steps: validate, scope, enrich and classify true or false positives.
- 4 Threat intelligence intro**
Use IOCs, TTPs, STIX/TAXII, MISP and the Pyramid of Pain to enrich alerts.
- 5 Incident response lifecycle**
Apply NIST SP 800-61 phases: preparation, detection, containment, eradication, recovery, lessons learned.
- 6 Digital forensics fundamentals**
Explain order of volatility, disk and memory images, hashing evidence and chain of custody.
- 7 Detection use cases and playbooks**
Write a brute force detection rule and a runbook with escalation and communication steps.

SIMULATED LABS

Hunt failed logins in a SIEM

Mock SIEM

Query auth logs for Event ID 4625 spikes and identify the source IP and targeted accounts.

Triage a phishing alert

Mock SIEM

Enrich a sender, URL and attachment hash with threat intel and decide the verdict.

Analyze a Linux auth.log

Log viewer

Find the SSH brute force, successful login and subsequent sudo activity.

Contain a compromised host

Scenario

Choose containment, eradication and recovery actions in order for a simulated infection.

Preserve evidence

File explorer

Hash disk image files, record chain of custody and sort evidence by order of volatility.

CHECKPOINT (30 min)

Log sources, SIEM queries, triage decisions, IOC use, IR phases, evidence handling

STAGE 3: OFFENSE, PRIVACY AND WRAP-UP

CORE-11

Offensive Security Intro

Intermediate

7 lessons | 5 labs | 5h 35m

- + Describe pentest phases and rules of engagement
- + Perform recon, scanning and enumeration in a sandbox
- + Report findings with evidence and remediation

LESSONS (15 min each)

- 1 Ethical hacking, scope and rules of engagement**
Explain authorization, scope, SOW, legal limits (CFAA) and pentest types (black, grey, white box).
- 2 Pentest methodology**
Walk through PTES phases: planning, recon, scanning, exploitation, post-exploitation, reporting.
- 3 Reconnaissance and OSINT**
Use whois, DNS, Google dorks, Shodan and theHarvester for passive and active recon.
- 4 Scanning and enumeration**
Use Nmap scan types, service and version detection, NSE and SMB or web enumeration.
- 5 Exploitation overview**
Explain exploit selection, Metasploit modules, payload types and web exploitation in lab scope.
- 6 Post-exploitation**
Describe privilege escalation, credential access, lateral movement and persistence, and cleanup.
- 7 Reporting and remediation advice**
Write an executive summary, findings with CVSS, reproduction steps and prioritized fixes.

SIMULATED LABS

Check scope before testing

Scenario

Read a rules-of-engagement document and decide which of 8 actions are in or out of scope.

Passive recon on a target

Web proxy

Gather subdomains, emails and tech stack from sandbox OSINT sources without touching the target.

Scan with Nmap

Terminal

Run host discovery, a service scan and NSE scripts, then interpret open ports and versions.

Exploit a vulnerable service

Terminal

Pick a matching Metasploit module in the sandbox, set options and obtain a shell.

Escalate privileges

Terminal

Enumerate SUID files and sudo rights on a sandbox host and gain root.

CHECKPOINT (30 min)

Scope and legality, PTES phases, Nmap output, exploit concepts, post-exploitation, report content

CORE-12

Privacy and Compliance

Beginner

4 lessons | 3 labs | 3h

- + Identify PII and classify data by sensitivity
- + Summarize GDPR and CCPA rights and obligations
- + Apply DLP, retention and compliance framework basics

LESSONS (15 min each)

- 1 PII, data classification and handling**
Classify data as public, internal, confidential or restricted and identify PII, PHI and cardholder data.
- 2 GDPR and CCPA basics**
Explain lawful basis, data subject rights, DPO, breach notification in 72 hours and CCPA opt-out rights.
- 3 DLP, retention and disposal**
Describe DLP detection and blocking, retention schedules, anonymization, pseudonymization and secure disposal.
- 4 Compliance frameworks overview**
Compare PCI DSS, HIPAA, SOX, SOC 2 and ISO 27001, and explain audits, evidence and risk registers.

SIMULATED LABS

Classify a data set

File explorer

Label sample files and database fields by sensitivity and pick the required handling for each.

Handle a data subject request

Scenario

Decide the steps and deadlines for an access or deletion request under GDPR.

Tune a DLP policy

Config editor

Write rules that block SSN and card numbers in outbound email while limiting false positives.

CHECKPOINT (30 min)

PII types, classification levels, GDPR rights and deadlines, DLP, framework purposes

CORE-13

Cloud Security Basics

Intermediate

5 lessons | 4 labs | 4h 25m

- + Apply the shared responsibility model by service type
- + Find IAM and storage misconfigurations
- + Describe container isolation and basic hardening

LESSONS (15 min each)

- 1 Cloud service and deployment models**
Compare IaaS, PaaS, SaaS and public, private, hybrid cloud, and shared responsibility per model.
- 2 Cloud IAM**
Write least-privilege policies, understand roles vs users, MFA on root, and key and access key hygiene.
- 3 Common cloud misconfigurations**
Identify open security groups, public snapshots, exposed secrets and missing logging (CloudTrail).
- 4 Storage exposure and data protection**
Check S3 and blob ACLs, public access blocks, encryption at rest, KMS and presigned URLs.
- 5 Containers 101**
Explain images, namespaces, cgroups, Docker vs VMs, registry risks, running as root and secrets in images.

SIMULATED LABS

Fix an over-permissive IAM policy

Config editor

Replace wildcard Action and Resource entries in a JSON policy with least-privilege permissions.

Audit a cloud storage bucket

File explorer

Find publicly readable objects and exposed credentials and apply a public access block.

Review cloud audit logs

Log viewer

Trace an access key abuse using CloudTrail events and identify the creating role and source IP.

Harden a Dockerfile

Code editor

Remove root user, pin the base image, drop embedded secrets and verify the fixed file.

CHECKPOINT (30 min)

Shared responsibility, IAM least privilege, storage exposure, misconfigs, container basics

CORE-14

Careers and Next Steps

Beginner

3 lessons | 2 labs | 2h 15m

- + Match certifications to career goals
- + Plan a portfolio that shows practical skills
- + Choose a specialization and a practice routine

LESSONS (15 min each)

- 1 Certification map**
Compare Security+, Network+, CySA+, eJPT, BTL1, CEH, SSCP and CISSP by level, focus and prerequisites.
- 2 Portfolio, labs and CTFs**
Build a portfolio with write-ups, a home lab and CTF practice on platforms like picoCTF and HackTheBox.
- 3 Choosing a specialization**
Compare SOC, pentest, GRC, cloud, DFIR, AppSec and engineering roles by daily work and skills.

SIMULATED LABS

Build a certification roadmap

Scenario

Pick a role goal and order 4 certifications with prerequisites and reasons.

Match skills to a role

Chat sim

Answer a career advisor's questions and get matched to a specialization with next steps.

CHECKPOINT (30 min)

Certification levels and focus, portfolio contents, role comparison

CORE-15

Capstone Review

Intermediate

2 lessons | 2 labs | 2h 20m

+ Recall core concepts across all Security Core modules

+ Solve mixed scenario questions under time

+ Identify weak areas to revisit

LESSONS (15 min each)

1 Mixed review across modules

Retrieve and connect principles, cryptography, web, network and defense concepts through mixed questions.

2 Final exam strategy and review

Apply scenario-question technique, eliminate distractors and review missed topics before the final exam.

SIMULATED LABS

Mixed incident scenario

Scenario

Work a multi-domain case from phishing to data exposure and choose the right control at each step.

Weak-area log review

Mock SIEM

Answer review tasks on alerts and logs from earlier modules and track which domains you missed.

CHECKPOINT (30 min)

Mixed questions from all 14 modules with emphasis on scenario judgment

Cyber Analyst (SOC)

92h 20m

Blue team path: detect, investigate and respond to attacks like a SOC analyst, from log reading to threat hunting.

Best for: People aiming at SOC analyst, incident responder, threat hunter or DFIR roles.

Needs: Security 101, especially Defensive Security Intro and Network Security.

Certification link: Overlaps CompTIA CySA+ and BTL1 topics (logs, SIEM, IR, phishing, forensics). Study guide only, not official prep.

CAPSTONE: Operation Quiet Beacon: Full Incident Investigation (6h)

Triage a mixed alert queue, then investigate a phishing-led intrusion using SIEM logs, a PCAP and an email, map to ATT&CK, contain, and write the report.

STAGE 1: ANALYST FOUNDATIONS

SOC-01

SOC Fundamentals

Beginner

5 lessons | 4 labs | 3h 45m

- + Describe SOC tiers, roles and the tools each uses
- + Walk an alert through its lifecycle within SLA targets
- + Calculate and interpret MTTD, MTTR and related metrics

LESSONS (15 min each)

- SOC structure and Tier 1-3 roles**
Explain how L1, L2, L3, SOC manager and engineering roles divide work and escalate.
- The SOC toolset**
Identify the purpose of SIEM, EDR, NDR, SOAR, ticketing and threat intel platforms in a SOC.
- Alert lifecycle and triage**
Walk an alert through detection, triage, enrichment, verdict, escalation and closure.
- SLAs, playbooks and shift handoffs**
Apply severity-based SLAs, follow a playbook step list and write a clear shift handoff note.
- SOC metrics: MTTD, MTTR and quality**
Compute MTTD, MTTR, false positive rate and alert volume, and explain what each reveals.

SIMULATED LABS

Sort the alert queue

Mock SIEM

Rank 10 queued alerts by severity and asset criticality, then assign each to a tier.

Follow the phishing playbook

Scenario

Choose the correct playbook step at each decision point for a reported email and record the outcome.

Write a shift handoff

Chat sim

Summarize open cases, pending actions and risks for the incoming analyst in a structured handoff.

Compute SOC metrics

Diagram

Place incident timestamps on a timeline and derive MTTD and MTTR for three cases.

CHECKPOINT (30 min)

SOC roles, alert lifecycle, SLA reasoning and computing MTTD/MTTR from timestamps

SOC-02

Log Analysis Essentials

Beginner

6 lessons | 4 labs | 4h

- + Recognize syslog, JSON and CEF log formats and their fields
- + Write regex to extract IPs, users and timestamps from logs
- + Correlate events from several sources into a timeline

LESSONS (15 min each)

- Log sources and types**
Classify OS, application, network device, authentication and cloud logs and what each can prove.
- Syslog format and severity levels**
Decode an RFC 5424 syslog line: PRI, facility, severity, timestamp, host and message.
- Structured logs: JSON and CEF**
Read JSON and CEF key-value records and map their fields to a common schema.
- Parsing and normalization**
Split raw lines into fields using delimiters, grok-style patterns and field renaming.
- Regex for log analysis**
Write regex with groups, quantifiers and anchors to pull IPv4 addresses, usernames and status codes.
- Correlation and timelines**
Align events by synchronized UTC time and pivot on IP, user or host to build an incident timeline.

SIMULATED LABS

Decode syslog priority

Log viewer

Compute facility and severity from PRI values and filter a feed to severity 3 and below.

Parse a CEF event

Code editor

Complete a parser that splits a CEF header and extension into named fields.

Regex extraction drill

Terminal

Use grep -oE and awk to extract failed-login source IPs and count them from a sample log.

Build a timeline

Log viewer

Merge firewall, auth and web logs, correct a timezone offset and order the events of an intrusion.

CHECKPOINT (30 min)

Log formats, regex extraction, timestamp normalization and cross-source correlation

SOC-03

Windows Event Logs and Sysmon

Intermediate

7 lessons | 5 labs | 5h 35m

- + Map key Windows event IDs to attacker behavior
- + Distinguish logon types and spot suspicious authentication
- + Use Sysmon and PowerShell logs to find execution and persistence

LESSONS (15 min each)

1 Windows logging architecture

Locate Security, System, Application and Operational logs and explain audit policy and channels.

2 Authentication events: 4624, 4625, 4634, 4672

Interpret successful, failed and privileged logons and the fields that identify the source.

3 Logon types and Kerberos/NTLM events

Tell logon types 2, 3, 5, 10 apart and read 4768, 4769 and 4776 for ticket and NTLM activity.

4 Account and group change events

Detect 4720, 4728, 4732, 4740 and 1102 to spot account creation, privilege change and log clearing.

5 Sysmon configuration and key events

Read Sysmon IDs 1, 3, 7, 8, 10, 11 and 13 and explain what a config such as SwiftOnSecurity adds.

6 Process creation and PowerShell logging

Use 4688 with command line, plus 4103/4104 script block logs, to decode encoded PowerShell.

7 Persistence artifacts

Find Run keys, scheduled tasks (4698), services (7045), WMI subscriptions and startup folder entries.

SIMULATED LABS

Failed logon triage

Log viewer

Filter 4625 events, identify brute force against one account and find the first success afterward.

Classify logon types

Mock SIEM

Query 4624 by LogonType and flag a type 10 logon from an external IP outside business hours.

Decode PowerShell

Terminal

Base64-decode an -enc command from event 4104 and list the download URL and behavior.

Sysmon process tree

Log viewer

Follow ParentProcessId from winword.exe to cmd.exe to powershell.exe using Sysmon event 1 records.

Find persistence

File explorer

Inspect Run keys, scheduled tasks and services in an exported host image and mark the malicious entries.

CHECKPOINT (30 min)

Event ID recall, logon types, Sysmon fields and persistence artifact identification

SOC-04

Linux and Web Server Logs

Intermediate

5 lessons | 4 labs | 4h 25m

- + Read auth.log, syslog and auditd records
- + Identify brute force, scanning and web attacks in access logs
- + Extract IOCs from Linux and web server logs with command-line tools

LESSONS (15 min each)

1 Linux log locations and syslog/journald

Find /var/log files and query journalctl by unit, priority and time range.

2 auth.log and SSH activity

Read sshd, sudo and su entries to find failed passwords, invalid users and accepted logins.

3 auditd rules and records

Interpret auditd SYSCALL, EXECVE and PATH records and write watch rules with auditctl -w.

4 Web access logs: Apache and Nginx

Parse combined log format fields and interpret status codes, user agents and referrers.

5 Spotting brute force and scanning

Detect credential stuffing, directory enumeration, SQLi and traversal patterns with grep, awk and sort|uniq.

SIMULATED LABS

SSH brute force hunt

Terminal

Use grep, awk and sort to rank source IPs of failed SSH logins and find any later success.

Read auditd events

Log viewer

Trace a file edit of /etc/passwd through auditd records to the responsible user and executable.

Web log scan detection

Log viewer

Spot a 404 burst from one IP, identify the scanner user agent and list probed paths.

Detect web exploitation

Terminal

Grep an access log for UNION SELECT and ../ patterns and identify the one request that returned 200.

CHECKPOINT (30 min)

auth.log and auditd fields, web log status codes and command-line pattern detection

SOC-05

SIEM Fundamentals

Intermediate

8 lessons | 6 labs | 6h 30m

- + Explain SIEM data flow from collection to alert
- + Write basic SPL and KQL searches with filters, stats and time ranges
- + Build dashboards and tune noisy detection rules

LESSONS (15 min each)

- 1 SIEM architecture and data flow**
Describe collectors, forwarders, indexers, search heads, retention tiers and hot/warm/cold storage.
- 2 Ingestion, parsing and normalization**
Explain agents vs agentless, syslog and API ingestion, and mapping to schemas such as CIM and ECS.
- 3 Search basics in SPL**
Write SPL with index, sourcetype, field filters, table, sort and time modifiers.
- 4 Aggregation in SPL and KQL**
Use stats count by, dedup, top and timechart in SPL, and summarize and bin in KQL.
- 5 KQL fundamentals**
Write KQL with where, project, extend, summarize and join against SecurityEvent and SigninLogs.
- 6 Dashboards and visualizations**
Choose panels, thresholds and drilldowns that show detection health and key hunting views.
- 7 Alert rules and correlation**
Build threshold, sequence and anomaly rules with suppression, throttling and severity mapping.
- 8 Tuning false positives**
Use allowlists, baselines and rule-level metrics to cut noise without losing true positives.

SIMULATED LABS

Search failed logons in SPL

Mock SIEM

Write an SPL query returning failed logons per user over 24 hours sorted by count.

Translate SPL to KQL

Code editor

Convert a given SPL stats search into the equivalent KQL summarize query.

Fix the broken parser

Config editor

Correct a field extraction so source IP and user populate and the search returns results.

Build a detection dashboard

Diagram

Arrange panels for top failed logons, new admins and outbound volume on a mobile layout.

Create a threshold alert

Mock SIEM

Configure a rule that fires on 10 failed logons in 5 minutes per source with 15 minute throttling.

Tune a noisy rule

Mock SIEM

Review 50 alerts, find the vulnerability scanner source causing 90 percent and add a safe exclusion.

CHECKPOINT (30 min)

SPL and KQL syntax, SIEM pipeline stages, alert logic and false positive tuning

STAGE 2: INVESTIGATION

SOC-06

Network Traffic Analysis

Intermediate

8 lessons | 6 labs | 6h 30m

- + Read packet headers and follow TCP streams in Wireshark
- + Triage a PCAP for DNS, HTTP and SMB abuse
- + Recognize beaconing and exfiltration with Zeek and Suricata output

LESSONS (15 min each)

- 1 Packet and protocol basics**
Read Ethernet, IP, TCP and UDP headers, TCP flags and the three-way handshake in a capture.
- 2 Wireshark workflow**
Apply capture vs display filters, follow streams, use Statistics menus and export objects.
- 3 PCAP triage method**
Start with Conversations, Protocol Hierarchy and Endpoints to find the interesting host quickly.
- 4 DNS analysis**
Spot DNS tunneling, DGA names, long TXT queries, high NXDOMAIN rates and fast-flux behavior.
- 5 HTTP analysis**
Identify C2 over HTTP, odd user agents, POST uploads, file downloads and exportable payloads.
- 6 SMB and lateral movement traffic**
Recognize SMB sessions, admin share access (ADMIN\$, IPC\$), named pipes and PsExec patterns.
- 7 Zeek logs and Suricata alerts**
Read conn.log, dns.log, http.log and eve.json alerts and pivot using the uid field.
- 8 Beaconing and exfiltration patterns**
Detect fixed-interval connections, jitter and large outbound transfers using flow statistics.

SIMULATED LABS

Filter a capture

Packet viewer

Apply display filters such as ip.addr, tcp.flags.syn and http.request to isolate a host's traffic.

Follow the TCP stream

Packet viewer

Follow a stream, read the plaintext HTTP exchange and extract the downloaded file name.

Find the DNS tunnel

Packet viewer

Identify the domain with abnormally long subdomain labels and count the queries it received.

Spot SMB lateral movement

Packet viewer

Locate ADMIN\$ writes and a service creation over SMB and name the source and target hosts.

Pivot through Zeek logs

Log viewer

Join conn.log and dns.log by uid to link an outbound connection to the domain it resolved.

Detect beaconing

Scenario

Compare connection interval charts for three hosts and select the one beaconing every 60 seconds.

CHECKPOINT (30 min)

Wireshark filters, protocol anomalies, Zeek/Suricata fields and beacon or exfiltration recognition

SOC-07

Endpoint Detection and Response

Intermediate

5 lessons | 4 labs | 4h 25m

- + Explain how EDR collects telemetry and generates detections
- + Read a process tree and identify living-off-the-land abuse
- + Triage an EDR alert and decide whether to isolate the host

LESSONS (15 min each)

1 EDR architecture and telemetry

Describe agent sensors, kernel callbacks, cloud analysis and what EDR sees compared with AV.

2 Process trees and parent-child analysis

Judge parent-child pairs such as winword to powershell, and use command lines, hashes and signers.

3 Living-off-the-land binaries

Recognize LOLBin abuse of certutil, mshta, rundll32, regsvr32, bitsadmin and wmic using LOLBAS.

4 EDR alert triage

Apply a triage checklist: scope, user, prior activity, prevalence, reputation and verdict.

5 Containment and host isolation

Decide when to isolate, kill processes, quarantine files, and document response actions.

SIMULATED LABS

Read the process tree

Log viewer

Trace a process tree from a phishing attachment to a child shell and name the suspicious step.

Spot the LOLBin

Terminal

Review five command lines and flag the certutil download and the rundll32 proxy execution.

Triage an EDR alert

Mock SIEM

Check host history, file prevalence and user context, then label the alert true or false positive.

Isolate the host

Scenario

Choose containment actions in order, then confirm isolation and record them in the case notes.

CHECKPOINT (30 min)

Process tree reasoning, LOLBin recognition and EDR triage and containment decisions

SOC-08

Phishing and Email Analysis

Intermediate

5 lessons | 4 labs | 4h 25m

- + Read email headers to trace sender path and spoofing
- + Interpret SPF, DKIM and DMARC results
- + Analyze URLs and attachments and run the user-report workflow

LESSONS (15 min each)

1 Email flow and header fields

Trace Received headers bottom-up and compare From, Reply-To, Return-Path and Message-ID.

2 SPF, DKIM and DMARC

Read Authentication-Results and explain alignment, DNS TXT records and DMARC policies.

3 URL analysis

Defang and unwind URLs, detect lookalike domains, redirects and shorteners, and check reputation safely.

4 Attachment analysis and sandboxing

Identify risky types (OLE macros, ISO, LNK, HTML), hash files and read sandbox verdicts.

5 User-report workflow

Handle a reported phish: acknowledge, analyze, search for other recipients, purge, block and report.

SIMULATED LABS

Trace the headers

Log viewer

Order Received headers, find the true originating IP and spot the mismatched Return-Path.

Read auth results

Config editor

Interpret SPF, DKIM and DMARC lines and fix a failing SPF TXT record in a sample zone.

Analyze the URL

Web proxy

Unwind a redirect chain in a sandbox, defang each hop and identify the credential harvesting page.

Phish response

Scenario

Work a reported email end to end: verdict, mailbox search, purge, indicator block and user reply.

CHECKPOINT (30 min)

Header analysis, SPF/DKIM/DMARC outcomes, URL and attachment indicators and response steps

SOC-09

Threat Intelligence

Intermediate

6 lessons | 4 labs | 4h 40m

- + Differentiate strategic, operational and tactical intelligence
- + Use IOCs, TTPs, STIX/TAXII and MISP to enrich and share intel
- + Apply the Diamond Model and OSINT to scope a threat

LESSONS (15 min each)

- 1 Intelligence types and the intel cycle**
Separate strategic, operational, tactical and technical intel and describe direction through feedback.
- 2 IOCs vs TTPs**
Explain the Pyramid of Pain and why behaviors outlast hashes, IPs and domains.
- 3 Intel formats: STIX and TAXII**
Read STIX 2.1 objects (indicator, malware, relationship) and explain TAXII collections.
- 4 MISP and intel platforms**
Use MISP events, attributes, tags, galaxies and correlations, and decide what to share under TLP.
- 5 Diamond Model and intel-driven defense**
Map adversary, capability, infrastructure and victim, and convert intel into detections and blocks.
- 6 OSINT for analysts**
Enrich IPs, domains and hashes with WHOIS, passive DNS, VirusTotal, Shodan and URLScan safely.

SIMULATED LABS

Enrich the indicator [Web proxy](#)

Look up a suspicious IP and domain in simulated VT, WHOIS and passive DNS and record the findings.

Sort IOCs and TTPs [Diagram](#)

Place indicators on the Pyramid of Pain and mark which are fragile and which are durable.

Read a STIX bundle [Code editor](#)

Read a STIX 2.1 JSON bundle and extract the indicator pattern and linked malware.

Build a Diamond model [Diagram](#)

Fill the four vertices from an incident report and pivot to a related infrastructure node.

CHECKPOINT (30 min)

Intel types, Pyramid of Pain, STIX/TAXII structure, MISP use and enrichment judgment

SOC-10

MITRE ATT&CK for Defenders

Intermediate

5 lessons | 4 labs | 4h 25m

- + Navigate ATT&CK tactics, techniques and sub-techniques
- + Map detections and incidents to technique IDs
- + Find coverage gaps using ATT&CK Navigator

LESSONS (15 min each)

- 1 ATT&CK matrix structure**
Name the Enterprise tactics in order and read technique, sub-technique, data source and mitigation entries.
- 2 Mapping incidents to techniques**
Translate observed behaviors into IDs such as T1059.001, T1566.001 and T1003.001.
- 3 Mapping detections to techniques**
Tag rules with technique IDs and judge detection quality from telemetry and analytic detail.
- 4 Coverage and gap analysis**
Compare detections against threat actor technique lists and prioritize by risk and data availability.
- 5 ATT&CK Navigator and layers**
Build and export Navigator layers with scores, colors and comments to present coverage.

SIMULATED LABS

Map the intrusion [Diagram](#)

Place the observed events of an incident onto the correct tactic columns and technique IDs.

Tag the rules [Mock SIEM](#)

Assign technique IDs to ten existing detection rules and note the data source each requires.

Build a Navigator layer [Scenario](#)

Score techniques for a threat actor and detections, then read the gap view.

Choose the next detection [Chat sim](#)

Justify which uncovered technique to build next based on actor use and available logs.

CHECKPOINT (30 min)

Tactic and technique recall, behavior-to-ID mapping and coverage gap prioritization

SOC-11

Malware Triage

Intermediate

6 lessons | 4 labs | 4h 40m

- + Triage a suspicious file with hashes, strings and metadata
- + Read sandbox reports to describe malware behavior
- + Handle samples safely and look up reputation correctly

LESSONS (15 min each)

1 Safe handling and lab hygiene

Apply isolation, defanging, password-protected archives (infected) and never executing on production.

2 Hashes and file identification

Calculate MD5, SHA-256 and ssdeep, check file type by magic bytes and spot extension tricks.

3 Strings and static triage

Use strings, PE headers, imports, packers and entropy to form a hypothesis without running the file.

4 Sandbox reports and behavior

Read process, file, registry and network behavior from Any.Run, Cuckoo or Joe Sandbox output.

5 VirusTotal and reputation

Interpret detection ratios, behavior tabs, relations and why privacy matters when uploading samples.

6 Common malware families

Recognize loaders, infostealers, RATs, ransomware and webshells and their typical behaviors.

SIMULATED LABS

Hash and identify

Terminal

Run sha256sum and file on a sample, detect the double extension and look up the hash.

Strings triage

Terminal

Search strings output for URLs, API names and mutexes and write a short verdict.

Read a sandbox report

Log viewer

Extract dropped files, persistence keys and C2 domains from a sandbox report.

Classify the family

Scenario

Match behavior sets (encrypting files, keylogging, beaconing) to the right malware class.

CHECKPOINT (30 min)

Static triage, sandbox report reading, reputation lookup judgment and safe handling

STAGE 3: RESPONSE AND ADVANCED DEFENSE

SOC-12

Incident Response

Intermediate

7 lessons | 5 labs | 5h 35m

- + Run the IR lifecycle from preparation to lessons learned
- + Choose containment, eradication and recovery actions
- + Preserve evidence and communicate during an incident

LESSONS (15 min each)

1 IR frameworks and lifecycle

Compare NIST SP 800-61 and SANS phases and describe the roles in an IR team.

2 Preparation and detection

Describe IR plans, retainers, tooling, asset inventory and incident classification and severity criteria.

3 Containment strategies

Weigh short-term vs long-term containment, network isolation, account disablement and business impact.

4 Eradication and recovery

Remove persistence, patch root cause, rebuild from known-good images and monitor after restore.

5 Evidence handling

Collect volatile data first, record who, what, when, hash images and keep chain of custody.

6 Communication and escalation

Notify legal, management and regulators on schedule and use need-to-know and out-of-band channels.

7 Post-incident review and playbooks

Run a blameless review, record timeline and root cause, and update playbooks and detections.

SIMULATED LABS

Classify the incident

Scenario

Assign type and severity for four events and select the matching IR playbook.

Contain the outbreak

Scenario

Select containment steps for a ransomware spread, weighing impact on critical services.

Eradicate persistence

Terminal

Find and remove a rogue scheduled task and service on a sandbox host and verify clean state.

Evidence collection order

Diagram

Order data sources by volatility and record chain of custody entries for each item.

Write the lessons learned

Chat sim

Draft a blameless review with timeline, root cause and three corrective actions.

CHECKPOINT (30 min)

IR phases, containment tradeoffs, evidence order of volatility and post-incident practice

SOC-13

Digital Forensics Essentials

Advanced

6 lessons | 4 labs | 5h 20m

- + Explain disk and memory forensics workflows
- + Build timelines from filesystem and log artifacts
- + Maintain chain of custody and use Autopsy and Volatility concepts

LESSONS (15 min each)

1 Forensic principles and chain of custody

Apply order of volatility, write blockers, hashing, documentation and admissibility basics.

2 Disk acquisition and file systems

Create a forensic image, verify hashes and explain NTFS structures such as MFT and \$UsnJrnl.

3 Windows artifacts

Interpret Prefetch, Shimcache, Amcache, LNK, jump lists, browser history and registry hives.

4 Timeline analysis

Build a super timeline from MAC times and logs and pivot around a time of interest.

5 Memory forensics with Volatility

Use pslist, psscan, netscan, malfind and cmdline plugins to spot injected or hidden processes.

6 Autopsy and reporting

Use Autopsy keyword search, hash sets and timeline view, and write a defensible findings report.

SIMULATED LABS

Verify the image

Terminal

Compute and compare hashes of an evidence image and log the custody entry.

Build a timeline

Log viewer

Merge MFT, event log and browser records and identify the minute data was staged.

Volatility triage

Terminal

Run pslist and malfind output review to find the injected process and its parent.

Autopsy keyword search

File explorer

Search an image for keywords, filter by hash set and flag the exfiltrated archive.

CHECKPOINT (30 min)

Chain of custody, Windows artifacts, timeline building and basic memory plugin interpretation

SOC-14

Detection Engineering

Advanced

7 lessons | 5 labs | 6h 25m

- + Write Sigma, YARA and Suricata rules from observed behavior
- + Test and tune detections against benign and malicious data
- + Manage detections as code with version control

LESSONS (15 min each)

1 Detection engineering lifecycle

Describe the cycle: requirement, hypothesis, build, test, deploy, measure and retire.

2 Sigma rules

Write Sigma logsource, detection selection, condition and falsepositives, then convert to SIEM queries.

3 Detection logic design

Balance specificity and resilience: command-line patterns, parent-child, rarity and thresholds.

4 YARA rules

Write YARA strings, hex and regex, conditions with filesize and uint16(0) and avoid slow rules.

5 Snort and Suricata rules

Write rules with action, header, content, pcre, flow, sid and understand their buffers.

6 Testing and tuning

Validate with Atomic Red Team, replayed logs and benign sets, then measure precision and noise.

7 Detection as code

Store rules in Git, use pull requests, CI validation, mapping tags and release changelogs.

SIMULATED LABS

Write a Sigma rule

Code editor

Complete a Sigma rule that detects encoded PowerShell launched from an Office process.

Fix an over-broad rule

Mock SIEM

Narrow a noisy detection with parent and command-line conditions and re-run to confirm.

Write a YARA rule

Code editor

Create a rule matching a packed sample's unique strings and run it against a clean set.

Suricata signature

Config editor

Write a rule that alerts on HTTP POST to a given URI with a specific user agent and test it on a PCAP.

Review a detection PR

Chat sim

Review a pull request for a rule, find the missing logsource and untested false positives.

CHECKPOINT (30 min)

Sigma, YARA and Suricata syntax, rule precision tradeoffs, testing methods and detection as code

SOC-15

Threat Hunting

Advanced

5 lessons | 4 labs | 5h 05m

- + Form testable hunt hypotheses from threat intel and ATT&CK
- + Select data sources and methods such as stacking and baselining
- + Document hunt results and convert findings into detections

LESSONS (15 min each)

- Hunting concepts and hypotheses**
Distinguish hunting from alert triage and write a testable hypothesis tied to a technique.
- Data sources and hunt scoping**
Match hypotheses to telemetry such as Sysmon, DNS and proxy logs and note collection gaps.
- Hunt methods: stacking and baselining**
Use least frequency analysis, grouping and baselines to surface rare processes and logons.
- Anomaly detection and beacon hunting**
Apply statistical thresholds, rare parent-child pairs, long connection and rare domain analysis.
- Hunt reporting and operationalizing**
Write findings with scope, evidence, gaps and recommendations and promote results to detections.

SIMULATED LABS

Write a hypothesis

Chat sim

Turn a threat report on scheduled task persistence into a hypothesis with data sources and scope.

Stack the processes

Mock SIEM

Run a least-frequency search over process names and spot the single masquerading binary.

Hunt for beacons

Log viewer

Group proxy logs by host and destination to find regular interval callbacks.

Write the hunt report

Scenario

Complete a hunt report listing evidence, a conclusion and the detection to create.

CHECKPOINT (30 min)

Hypothesis quality, data source selection, stacking and baselining and hunt reporting

SOC-16

Cloud and Identity Detection

Advanced

5 lessons | 4 labs | 5h 05m

- + Read CloudTrail and Entra ID sign-in logs to trace activity
- + Detect password spraying, token theft and risky sign-ins
- + Triage SaaS and identity alerts and respond with correct actions

LESSONS (15 min each)

- Cloud logging fundamentals**
Explain CloudTrail management vs data events, Entra sign-in and audit logs and log retention.
- Reading CloudTrail**
Interpret eventName, userIdentity, sourceIPAddress and errorCode to trace API activity and role assumption.
- Entra ID sign-in analysis**
Read result codes, conditional access status, MFA details and risk levels for each sign-in.
- Password spraying and token theft**
Detect one-password-many-accounts patterns, AiTM phishing, session cookie replay and MFA fatigue.
- SaaS alerts and identity response**
Triage impossible travel, inbox rules and OAuth grants, then revoke sessions and reset credentials.

SIMULATED LABS

Trace CloudTrail activity

Log viewer

Follow an access key through AssumeRole to a bucket policy change and name the actor.

Detect a password spray

Mock SIEM

Query sign-in failures by IP across accounts to show one source trying one password on many users.

Spot token replay

Log viewer

Compare two sign-ins with the same session ID from different IPs and flag token theft.

Respond to account takeover

Scenario

Choose revoke sessions, reset password, remove malicious inbox rule and review OAuth grants in order.

CHECKPOINT (30 min)

CloudTrail and Entra log fields, spray and token theft indicators and identity response steps

SOC-17

SOC Reporting and Communication

Intermediate

3 lessons | 2 labs | 2h 35m

- + Write clear incident reports with facts, impact and timeline
- + Escalate with the right content to the right audience
- + Document cases in a ticketing system with consistent detail

LESSONS (15 min each)

- Incident report structure**
Write a report with summary, scope, timeline in UTC, evidence, root cause and recommendations.
- Escalation and executive summaries**
Separate facts from assumptions and tailor a short business-impact summary for non-technical leaders.
- Ticketing and case documentation**
Record observables, actions, verdict and handoff details so another analyst can continue without questions.

SIMULATED LABS

Write the incident report

Chat sim

Turn raw case notes into a structured report with a UTC timeline and a plain-language summary.

Draft the escalation

Scenario

Choose which facts, impact and ask belong in an escalation to the incident manager.

CHECKPOINT (30 min)

Report structure, factual precision, audience-appropriate escalation and case documentation

SOC-18

Capstone: Investigate an Incident

Advanced

3 lessons | 2 labs | 2h 55m

- + Triage a mixed alert queue and prioritize by risk
- + Pivot across logs, a PCAP and an email to scope an incident
- + Deliver a verdict, response actions and a written report

LESSONS (15 min each)

1 Alert queue triage and initial scoping

Prioritize multiple alerts, decide what is related and open a case with initial hypotheses.

2 Cross-source investigation

Pivot between SIEM logs, a PCAP and a phishing email, mapping each finding to ATT&CK.

3 Response, report and review

Select containment, write the incident report with timeline and recommendations, and note detection gaps.

SIMULATED LABS

Capstone investigation

Scenario

Triage an alert queue, pivot across logs, a PCAP and a phishing email, and build the full attack timeline.

Capstone report and response

Chat sim

Submit containment actions, an ATT&CK mapping and a summary for a manager, then answer review questions.

CHECKPOINT (30 min)

End-to-end investigation: prioritization, cross-source correlation, containment and reporting

Penetration Testing

112h 10m

Red team path: think like an attacker, in authorized and legal scenarios, from recon to reporting.

Best for: People aiming at penetration tester, red team or application security roles.

Needs: Security 101 (Offensive Security Intro), plus Linux and Networking.

CAPSTONE (8h)

STAGE 1: FOUNDATIONS OF TESTING

PEN-01

Methodology, Scope and Law

Beginner

5 lessons | 4 labs | 3h 45m

Covers: Test phases (PTES, OWASP WSTG, NIST SP 800-115), scoping, rules of engagement, authorization, ethics, reporting overview.

5 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-02

Reconnaissance and OSINT

Intermediate

6 lessons | 4 labs | 4h 40m

Covers: Passive vs active recon, DNS enumeration, WHOIS, subdomain discovery, search dorking, metadata, Shodan and Censys.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-03

Scanning and Enumeration

Intermediate

8 lessons | 6 labs | 6h 30m

Covers: Nmap (host discovery, scan types, versions, scripts), banner grabbing, enumerating SMB, FTP, SSH, SNMP and HTTP.

8 lessons and 6 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-04

Vulnerability Assessment

Intermediate

4 lessons | 3 labs | 3h 30m

Covers: Scanner concepts (Nessus, OpenVAS), manual verification, prioritization, handling false positives.

4 lessons and 3 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

STAGE 2: WEB AND API

PEN-05

Web App Pentesting I

Intermediate

7 lessons | 5 labs | 5h 35m

Covers: Proxy tools (Burp, ZAP), mapping the app, authentication and session testing, access control and IDOR, input validation.

7 lessons and 5 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-06

Web App Pentesting II

Advanced

10 lessons | 7 labs | 8h 50m

Covers: SQL injection, XSS, CSRF, SSRF, file upload flaws, XXE, deserialization, path traversal, command injection, business logic flaws.

10 lessons and 7 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-07

API and Mobile Testing

Advanced

6 lessons | 4 labs | 5h 20m

Covers: REST and GraphQL testing, JWT issues, broken object level authorization, rate limiting, Android basics and OWASP MASVS.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

STAGE 3: NETWORK AND SYSTEMS

PEN-08

Network Pentesting

Intermediate

8 lessons | 6 labs | 6h 30m

Covers: Service exploitation concepts, the Metasploit framework, credential attacks, sniffing and MITM, safe exploitation practice.

8 lessons and 6 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-09

Password and Hash Cracking

Intermediate

5 lessons | 4 labs | 4h 25m

Covers: Hash types, Hashcat and John concepts, wordlists and rules, salting, pass-the-hash overview.

5 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-10

Linux Privilege Escalation

Advanced

6 lessons | 4 labs | 5h 20m

Covers: Enumeration, SUID, sudo misconfigurations, cron jobs, capabilities, kernel exploits at concept level.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-11

Windows Privilege Escalation

Advanced

6 lessons | 4 labs | 5h 20m

Covers: Services, tokens, registry, unquoted paths, UAC bypass concepts, credential hunting.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-12

Active Directory Attacks

Advanced

10 lessons | 7 labs | 8h 50m

Covers: AD concepts, Kerberos and NTLM, enumeration with BloodHound, Kerberoasting, AS-REP roasting, pass-the-ticket, lateral movement, defenses.

10 lessons and 7 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

STAGE 4: ADVANCED AND PROFESSIONAL

PEN-13

Post-Exploitation and Pivoting

Advanced

6 lessons | 4 labs | 5h 20m

Covers: Tunneling and port forwarding, lateral movement, persistence concepts, data exfiltration, cleanup.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-14

Wireless and Physical Security

Intermediate

4 lessons | 3 labs | 3h 30m

Covers: WPA attack overview, rogue access points, physical access testing, badge cloning concepts.

4 lessons and 3 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-15

Social Engineering Engagements

Intermediate

4 lessons | 3 labs | 3h 30m

Covers: Authorized phishing campaigns, pretexting, vishing, measuring awareness.

4 lessons and 3 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-16

Cloud Pentesting

Advanced

6 lessons | 4 labs | 5h 20m

Covers: Cloud IAM abuse, storage misconfigurations, metadata service, serverless and container escapes at concept level.

6 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-17

Binary Exploitation Basics

Advanced

7 lessons | 5 labs | 6h 25m

Covers: Memory layout, stack and buffer overflows, shellcode concept, ASLR and DEP, reverse engineering intro.

7 lessons and 5 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-18

Red Team Fundamentals

Advanced

5 lessons | 4 labs | 5h 05m

Covers: Adversary emulation, C2 concepts, OPSEC, evasion at concept level, purple teaming.

5 lessons and 4 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-19

Reporting and Communication

Intermediate

4 lessons | 3 labs | 3h 30m

Covers: Writing findings, risk rating, remediation advice, executive summaries, retesting.

4 lessons and 3 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

PEN-20

Capstone: Full Engagement

Advanced

3 lessons | 2 labs | 2h 55m

Covers: A guided assessment from scope to final report.

3 lessons and 2 simulated labs planned. The lesson-by-lesson plan for this path is not written yet.

Security Engineering

97h 45m

Build security in: architecture, hardening, identity, cloud, DevSecOps, automation and governance.

Best for: Sysadmins and developers moving into security engineering or DevSecOps.

Needs: Security 101, plus Scripting Basics from Pre-Security.

Certification link: Overlaps CISSP domains 3, 4, 5, 8; AWS Security Specialty; CKS topics. Study guide only, not an official prep.

CAPSTONE: Secure a Company: Design Review and Hardening (6h)

Multi-step simulated engagement: threat model the architecture, fix IAM, network, cloud and pipeline findings, set up detection, then present a prioritized roadmap.

STAGE 1: DESIGN AND HARDENING

ENG-01

Secure Architecture and Threat Modeling

Intermediate

6 lessons | 4 labs | 4h 40m

- + Decompose a system into a data flow diagram with trust boundaries
- + Apply STRIDE and attack trees to rank threats and pick mitigations
- + Design layered controls using zero trust and defense in depth

LESSONS (15 min each)

- Threat modeling process and DFDs**
Explain the four-question threat modeling process and draw a DFD with its core element types.
- Trust boundaries and attack surface**
Identify trust boundaries and entry points in a DFD and explain why data crossing them needs validation.
- STRIDE per element**
Map each STRIDE category to the security property it violates and to typical mitigations per DFD element type.
- PASTA and attack trees**
Describe the seven PASTA stages and build an attack tree with AND/OR nodes and leaf-level cost or likelihood.
- Secure design patterns and principles**
Apply least privilege, fail-safe defaults, complete mediation and separation of duties to a design.
- Zero trust and defense in depth**
Explain NIST SP 800-207 zero trust tenets and place layered controls across network, host, app and data.

SIMULATED LABS

Draw the DFD

Diagram

Place processes, stores and entities for a web app, connect flows and mark the trust boundaries.

STRIDE a login flow

Scenario

For each element of a login DFD, choose the applicable STRIDE threats and a matching mitigation.

Build an attack tree

Diagram

Arrange AND/OR nodes to reach the goal 'steal customer data' and mark the cheapest path.

Layer the defenses

Config editor

Assign controls to network, host, app and data layers so no single failure exposes the asset.

CHECKPOINT (30 min)

STRIDE mapping, trust boundaries, attack trees, secure design principles, zero trust tenets

ENG-02

System Hardening

Intermediate

6 lessons | 4 labs | 4h 40m

- + Apply CIS Benchmark controls to Linux and Windows systems
- + Build a patch and configuration management workflow with baselines
- + Detect configuration drift against a hardened baseline

LESSONS (15 min each)

- Hardening principles and CIS Benchmarks**
Explain attack surface reduction, CIS Level 1 versus Level 2 profiles and how benchmarks are scored.
- Linux hardening**
Harden SSH (PermitRootLogin, key auth), sysctl, file permissions, auditd, and remove unneeded services.
- Windows hardening**
Apply Group Policy, local security policy, Defender, BitLocker and disabling SMBv1/LLMNR/NTLM where possible.
- Patch management lifecycle**
Describe inventory, test, staged rollout, rollback and emergency patching with WSUS, apt/yum and Intune.
- Configuration management tools**
Use Ansible, Puppet or DSC to enforce idempotent desired-state configuration at scale.
- Baselines, drift and compliance scanning**
Create gold images, scan with OpenSCAP or Lynis, and handle drift and documented exceptions.

SIMULATED LABS

Harden sshd_config

Config editor

Edit an sshd_config to disable root login and password auth, set ciphers, and restrict users.

Audit a Linux host

Terminal

Run Lynis-style checks, read the findings and fix the failing permission and service items.

Windows GPO review

Config editor

Toggle policy settings to meet a baseline: SMBv1 off, NTLM restricted, audit policy set.

Patch rollout plan

Scenario

Order systems into rings, choose test and rollback steps, and handle an emergency out-of-band patch.

CHECKPOINT (30 min)

CIS benchmark profiles, SSH and Windows policy settings, patch lifecycle, config management, drift

ENG-03

Identity and Access Engineering

Intermediate

7 lessons | 5 labs | 5h 35m

- + Configure SSO using SAML and OIDC and read their tokens
- + Design MFA, PAM and service account controls
- + Store and rotate secrets without hardcoding them

LESSONS (15 min each)

- 1 Directory services and AD architecture**
Explain LDAP, Kerberos, Active Directory domains, OUs, groups and tiered administration.
- 2 AuthN, AuthZ and access models**
Distinguish RBAC, ABAC and ReBAC, and apply least privilege and joiner-mover-leaver processes.
- 3 SAML federation**
Trace a SAML SP-initiated flow and check assertions, signatures, audience and NotOnOrAfter.
- 4 OAuth 2.0 and OIDC**
Use authorization code with PKCE and validate ID token claims (iss, aud, exp, nonce) and scopes.
- 5 MFA rollout**
Compare TOTP, push and FIDO2/WebAuthn, plan phased enrollment, recovery, and mitigate MFA fatigue.
- 6 Privileged access management**
Implement vaulting, just-in-time elevation, session recording and break-glass accounts.
- 7 Service accounts and secrets**
Replace static credentials with managed identities, short-lived tokens and Vault-style rotation.

SIMULATED LABS

Decode a SAML assertion

Web proxy

Inspect an intercepted SAML response and spot the missing signature check and wrong audience.

Inspect an OIDC token

Code editor

Decode a JWT, verify claims and fix a validation bug that accepts alg none.

MFA rollout plan

Scenario

Choose factors per user group, set enrollment order and a safe recovery process.

Audit AD groups

File explorer

Browse group memberships, find stale admins and nested privilege paths, and flag them.

Remove hardcoded secrets

Code editor

Replace credentials in a script with environment-injected secrets and a Vault lookup.

CHECKPOINT (30 min)

SAML versus OIDC flows, token validation, MFA types, PAM, service account and secret handling

ENG-04

Network Security Engineering

Intermediate

7 lessons | 5 labs | 5h 35m

- + Design firewall rules and segmented network zones
- + Choose VPN, ZTNA, WAF and NAC controls for a given need
- + Defend DNS and absorb DDoS attacks

LESSONS (15 min each)

- 1 Firewall types and rule design**
Compare stateless, stateful and NGFW, and write ordered allow-list rules with default deny.
- 2 Network segmentation and zones**
Design DMZ, internal, management and OT zones with VLANs and ACLs between them.
- 3 Microsegmentation**
Apply host- and workload-level policy to limit east-west movement using tags and identity.
- 4 VPN and ZTNA**
Compare IPsec, WireGuard and SSL VPN with identity-aware ZTNA and decide when each fits.
- 5 WAF and reverse proxies**
Deploy a WAF in detection then blocking mode with OWASP CRS and tune false positives.
- 6 DNS security and DDoS defense**
Use DNSSEC, DoT/DoH, RPZ, rate limiting, anycast, scrubbing and SYN cookies.
- 7 Network access control**
Implement 802.1X, RADIUS, posture checks and quarantine VLANs for unmanaged devices.

SIMULATED LABS

Write firewall rules

Config editor

Build an ordered rule set for a three-tier app with default deny and least-open ports.

Segment the network

Diagram

Place zones and firewalls on a diagram and mark allowed flows between them.

Tune a WAF

Log viewer

Read WAF blocks, separate real attacks from false positives, and write exclusions.

Spot DNS abuse

Packet viewer

Find DNS tunneling and a spoofed response in a capture and propose DNS controls.

Pick the right access control

Scenario

Given five remote-access requirements, choose between VPN, ZTNA and NAC with reasons.

CHECKPOINT (30 min)

Rule ordering, segmentation design, VPN versus ZTNA, WAF tuning, DNS and DDoS controls, 802.1X

ENG-05

Cryptography in Practice

Intermediate

6 lessons | 4 labs | 4h 40m

- + Configure TLS securely and manage certificate lifecycles
- + Design key management with KMS, HSM and rotation
- + Identify and fix common cryptographic implementation mistakes

LESSONS (15 min each)

- 1 TLS configuration**
Choose TLS 1.2/1.3, AEAD cipher suites, forward secrecy, HSTS and test with testssl.sh.
- 2 PKI and certificate lifecycle**
Explain chains, CAs, ACME, OCSP stapling, CT logs and automated renewal to avoid expiry outages.
- 3 KMS and envelope encryption**
Use a KMS with data keys, key policies, and separation of key and data access.
- 4 HSMs and key rotation**
Compare HSM, FIPS 140-3 levels and rotation, escrow and destruction procedures.
- 5 Secrets management**
Operate Vault or cloud secrets managers with dynamic secrets, leases and audit logging.
- 6 Common implementation mistakes**
Spot ECB mode, nonce reuse, weak password hashing, hardcoded keys and unsafe randomness, and fix them.

SIMULATED LABS

Fix a TLS config

Config editor

Edit an nginx TLS block to disable old protocols and weak ciphers and enable HSTS.

Triage an expired cert

Terminal

Use openssl s_client to find the expired intermediate and plan the renewal.

Envelope encryption flow

Diagram

Order the steps of data key generation, encryption, wrapping and storage.

Review crypto code

Code editor

Find and replace MD5, ECB and a static IV in a code sample with safe alternatives.

CHECKPOINT (30 min)

TLS settings, certificate lifecycle and ACME, KMS and envelope encryption, rotation, crypto misuse

STAGE 2: SECURE SOFTWARE AND PLATFORMS

ENG-06

Application Security

Intermediate

8 lessons | 6 labs | 6h 30m

- + Write code that avoids OWASP Top 10 flaws
- + Run and triage SAST, DAST and SCA results
- + Operate a secure SDLC with reviews and security champions

LESSONS (15 min each)

- 1 Secure SDLC and requirements**
Integrate security activities in each SDLC phase using OWASP SAMM and BSIMM concepts.
- 2 Input validation and output encoding**
Apply allow-list validation, parameterized queries and context-aware output encoding.
- 3 Authentication and session handling**
Implement secure password storage (Argon2/bcrypt), session cookies flags and CSRF defenses.
- 4 Access control and API security**
Enforce server-side authorization and prevent IDOR, mass assignment and broken function-level access.
- 5 Secure code review**
Review code with a checklist for injection, authz, crypto and error handling issues.
- 6 SAST and DAST**
Compare Semgrep/CodeQL with ZAP-style scanning and tune rules to reduce false positives.
- 7 SCA and dependency risk**
Read SBOM and CVE data for dependencies, handle transitive risk and pin versions.
- 8 Security champions program**
Set up a champion network, training, threat model reviews and vulnerability SLAs.

SIMULATED LABS

Fix SQL injection

Code editor

Convert string-built queries to parameterized statements and verify the exploit fails.

Fix XSS output

Code editor

Apply the right encoder per context and add a CSP header to a vulnerable template.

Review a pull request

Code editor

Annotate a diff for missing authz checks and unsafe deserialization.

Triage SAST findings

Scenario

Classify a findings list into true positive, false positive and risk accepted with reasons.

Exploit an IDOR in sandbox

Web proxy

Modify an object ID in a request, confirm unauthorized access, then specify the fix.

Dependency audit

Terminal

Run an SCA scan on a lockfile and choose upgrade paths for vulnerable packages.

CHECKPOINT (30 min)

OWASP Top 10 fixes, secure review, SAST/DAST/SCA triage, session and authz handling, SDLC

ENG-07

DevSecOps and CI/CD Security

Advanced

7 lessons | 5 labs | 6h 25m

- + Find and fix weaknesses in CI/CD pipelines
- + Generate SBOMs and sign artifacts
- + Enforce security rules with policy as code

LESSONS (15 min each)

- 1 CI/CD threat model**
Map pipeline attack points: source, build, runners, dependencies, registries and deploy credentials.
- 2 Pipeline hardening**
Secure runners, restrict tokens, pin actions by SHA and use OIDC federation instead of long-lived keys.
- 3 Secrets in repos**
Detect leaked secrets with gitleaks/trufflehog, use pre-commit hooks and revoke and rotate exposed keys.
- 4 Artifact signing and provenance**
Sign images and builds with Sigstore cosign and verify signatures before deployment.
- 5 SBOM and vulnerability data**
Produce SPDX or CycloneDX SBOMs with Syft and scan with Gripe, and use VEX statements.
- 6 Supply chain security and SLSA**
Explain SLSA levels, dependency confusion and typosquatting, and mitigations such as lockfiles.
- 7 Policy as code gates**
Write OPA/Rego or Conftest rules that block risky builds and deployments.

SIMULATED LABS

Harden a workflow file

Config editor

Fix a CI YAML: pin actions, limit token permissions and remove a plaintext secret.

Scan repo for secrets

Terminal

Run a secret scanner over history, identify true leaks and plan rotation.

Verify a signature

Terminal

Check an image signature and refuse deployment when verification fails.

Read an SBOM

File explorer

Locate a vulnerable transitive package in an SBOM and trace which service uses it.

Write a Rego rule

Code editor

Write a policy denying images from unapproved registries and test it on sample input.

CHECKPOINT (30 min)

Pipeline attack paths, secret scanning, signing and provenance, SBOM, SLSA, policy as code

ENG-08

Cloud Security Engineering

Advanced

9 lessons | 6 labs | 7h 45m

- + Design secure IAM and network controls in AWS, Azure and GCP
- + Configure encryption, logging and CSPM in the cloud
- + Plan a multi-account landing zone

LESSONS (15 min each)

- 1 Shared responsibility and cloud threat model**
Explain the shared responsibility model per IaaS, PaaS and SaaS and common cloud attack paths.
- 2 Cloud IAM fundamentals**
Read IAM policies, roles, trust relationships and SCP/Org policy boundaries across clouds.
- 3 IAM least privilege in practice**
Reduce permissions using Access Analyzer, conditions, permission boundaries and short-lived credentials.
- 4 Cloud network controls**
Design VPC/VNet segmentation, security groups, private endpoints and egress control.
- 5 Data protection and encryption**
Apply KMS-based encryption at rest, bucket and storage policies and block public exposure.
- 6 Logging and detection**
Enable CloudTrail, Azure Activity Log and GCP Audit Logs and centralize them for detection.
- 7 CSPM and misconfiguration**
Use CSPM to find public buckets, open security groups and unencrypted volumes and prioritize.
- 8 Landing zones and multi-account design**
Structure organizations, OUs, guardrails, and baseline accounts with Control Tower-style patterns.
- 9 Cloud pattern comparison**
Map equivalent services across AWS, Azure and GCP and pick patterns for common workloads.

SIMULATED LABS

Fix an IAM policy

Config editor

Replace a wildcard policy with scoped actions, resources and conditions.

Trace a privilege escalation

Scenario

Follow an IAM path from low-privilege role to admin and break the chain.

Lock down a bucket

Config editor

Enable block public access, encryption and logging on a storage bucket policy.

Hunt in CloudTrail

Log viewer

Find the console login without MFA and the key creation that followed.

Triage CSPM findings

Mock SIEM

Sort misconfiguration alerts by exposure and data sensitivity and fix the top three.

Design a landing zone

Diagram

Lay out OUs, accounts and guardrail policies for prod, dev and security tooling.

CHECKPOINT (30 min)

IAM policy reading, privilege escalation, cloud network and data controls, logging, CSPM

ENG-09

Container and Kubernetes Security

Advanced

7 lessons | 5 labs | 6h 25m

- + Scan and harden container images
- + Configure Kubernetes RBAC, network and pod security
- + Detect runtime threats and protect secrets in clusters

LESSONS (15 min each)

- 1 Container security fundamentals**
Explain namespaces, cgroups, capabilities and why containers share a kernel with the host.
- 2 Image security and scanning**
Build minimal non-root images, scan with Trivy, and enforce trusted registries and digests.
- 3 Kubernetes architecture and attack surface**
Identify API server, etcd, kubelet and service account exposure risks.
- 4 RBAC in Kubernetes**
Write Roles and RoleBindings with least privilege and audit with kubect auth can-i.
- 5 Pod security and admission control**
Apply Pod Security Standards, securityContext and admission policies (Kyverno, Gatekeeper).
- 6 Network policies**
Create default-deny NetworkPolicies and allow only required pod-to-pod traffic.
- 7 Runtime security and secrets**
Use Falco rules, seccomp and AppArmor, and handle secrets with encryption at rest and external stores.

SIMULATED LABS

Scan an image

Terminal

Run a Trivy-style scan, read CVE output and rebuild the image with a patched base.

Harden a Dockerfile

Code editor

Switch to non-root user, minimal base, remove secrets and add a healthcheck.

Fix over-broad RBAC

Config editor

Replace a cluster-admin binding with a namespaced least-privilege Role.

Write a NetworkPolicy

Config editor

Create default-deny and allow only the frontend to reach the API on its port.

Investigate a Falco alert

Log viewer

Read a runtime alert for a shell in a container and decide on containment.

CHECKPOINT (30 min)

Image hardening, RBAC, pod security standards, network policy, Falco and secrets

ENG-10

Infrastructure as Code Security

Advanced

4 lessons | 3 labs | 4h

- + Scan Terraform and CloudFormation for misconfigurations
- + Detect and remediate infrastructure drift
- + Enforce guardrails with policy as code

LESSONS (15 min each)

- 1 IaC security risks**
Explain IaC misconfigurations, secrets in state files and the benefits of shift-left scanning.
- 2 Scanning IaC templates**
Use Checkov, tfsec or cfn-nag to find and fix insecure resources and tune suppressions.
- 3 Drift detection and state security**
Detect drift with plan or AWS Config, protect remote state with encryption and locking.
- 4 Guardrails and policy as code**
Apply OPA, Sentinel and SCPs to enforce standards before and after deployment.

SIMULATED LABS

Fix a Terraform file

Code editor

Correct an S3 bucket and security group to pass scanner checks.

Triage drift

Terminal

Read a terraform plan showing manual changes and decide to revert or codify.

Write a guardrail

Config editor

Author a policy that blocks public ingress on port 22 and test it.

CHECKPOINT (30 min)

IaC scanner findings, state security, drift handling, policy as code guardrails

STAGE 3: OPERATE AND GOVERN

ENG-11

Logging and Monitoring Architecture

Intermediate

5 lessons | 4 labs | 4h 25m

- + Design a log pipeline with the right sources and retention
- + Engineer SIEM detections and tune alerts
- + Define metrics for monitoring coverage

LESSONS (15 min each)

- 1 Log sources and pipeline design**
Select sources (auth, endpoint, network, cloud) and design collection with agents, syslog and normalization.
- 2 SIEM engineering and parsing**
Build parsers, field mappings (ECS/CIM), time sync and enrichment for reliable search.
- 3 Detection and alert design**
Write detection rules mapped to MITRE ATT&CK with thresholds, severity and runbooks.
- 4 Retention, integrity and compliance**
Set hot/warm/cold retention, protect log integrity and meet regulatory minimums.
- 5 Metrics and detection coverage**
Track log source health, MTTD, false positive rate and ATT&CK coverage.

SIMULATED LABS

Fix a parser

Log viewer

Correct field extraction so source IP and user appear in the normalized event.

Write a detection

Mock SIEM

Build a query for repeated failed logins followed by success and set a threshold.

Tune a noisy alert

Mock SIEM

Reduce false positives with allow-lists and context while keeping true positives.

Plan retention

Scenario

Assign retention periods to log types to meet a compliance and cost target.

CHECKPOINT (30 min)

Log source choice, parsing, detection rule design, retention, detection metrics

ENG-12

Vulnerability and Patch Programs

Intermediate

5 lessons | 4 labs | 4h 25m

- + Build an asset inventory that drives scanning
- + Prioritize vulnerabilities with CVSS, EPSS and KEV
- + Run SLA and exception processes

LESSONS (15 min each)

- 1 Asset inventory and attack surface**
Combine CMDB, cloud APIs and discovery scans to keep an accurate inventory with owners.
- 2 Scanning cadence and coverage**
Plan authenticated versus unauthenticated scans, agents and scan windows without breaking services.
- 3 Risk-based prioritization**
Prioritize using CVSS, EPSS, CISA KEV, exposure and asset criticality instead of score alone.
- 4 Remediation SLAs and reporting**
Define SLAs by severity, track aging and report to owners with tickets and dashboards.
- 5 Exceptions and compensating controls**
Run risk-accepted exceptions with expiry, approvals and compensating controls.

SIMULATED LABS

Reconcile inventory

File explorer

Compare scanner results to the CMDB and find unmanaged and unowned assets.

Prioritize the backlog

Scenario

Rank 10 CVEs using EPSS, KEV status and asset exposure and justify the order.

Read a scan report

Log viewer

Separate false positives from real findings in an authenticated scan output.

Handle an exception

Chat sim

Negotiate with an app owner and document a time-boxed exception with a compensating control.

CHECKPOINT (30 min)

Inventory, scan cadence, CVSS/EPSS/KEV prioritization, SLAs, exception handling

ENG-13

Endpoint and Email Security

Intermediate

5 lessons | 4 labs | 4h 25m

- + Roll out EDR and MDM in phases
- + Deploy SPF, DKIM and DMARC without breaking mail
- + Harden browsers and email gateways

LESSONS (15 min each)

- 1 EDR selection and rollout**
Plan EDR pilots, sensor coverage, exclusions, tamper protection and response actions.
- 2 MDM and device compliance**
Enforce encryption, passcode, OS version and conditional access with MDM for managed devices.
- 3 Email gateway and phishing defense**
Configure filtering, attachment sandboxing, link rewriting and user report workflows.
- 4 SPF, DKIM and DMARC rollout**
Move DMARC from p=none to quarantine to reject using aggregate reports.
- 5 Browser security**
Apply browser policies, extension control, safe browsing and isolation for risky content.

SIMULATED LABS

Triage EDR coverage

Mock SIEM

Find hosts missing the sensor or in reduced functionality mode and plan fixes.

Fix DMARC records

Config editor

Edit SPF, DKIM and DMARC DNS records based on aggregate report failures.

Analyze a phish

Log viewer

Read headers to find spoofing and the failing authentication results.

Set MDM policy

Config editor

Configure compliance rules and conditional access for a BYOD group.

CHECKPOINT (30 min)

EDR rollout, MDM compliance, DMARC stages, email filtering, browser hardening

ENG-14

Security Automation and Scripting

Advanced

7 lessons | 5 labs | 6h 25m

- + Write Python and Bash that call security APIs
- + Build SOAR playbooks that automate triage and response
- + Write infrastructure tests for security controls

LESSONS (15 min each)

- 1 Bash for security tasks**
Use grep, awk, jq, find and loops safely with quoting and set -euo pipefail.
- 2 Python for security engineering**
Parse logs, handle files and use regex, argparse and virtual environments for tooling.
- 3 Working with REST APIs**
Call APIs with requests, handle auth, pagination, rate limits, retries and error codes.
- 4 Automating enrichment and triage**
Enrich IOCs from threat intel APIs and score alerts automatically.
- 5 SOAR playbooks**
Design playbooks with triggers, branching, approval steps and safe response actions.
- 6 Automated response safely**
Add guardrails, dry-run modes, logging and rollback to automated containment.
- 7 Infrastructure and security tests**
Write testinfra, InSpec or pytest checks that verify hardening and detect regressions.

SIMULATED LABS

Parse auth logs

Code editor

Write Python that counts failed logins per IP and flags those above a threshold.

jq pipeline

Terminal

Extract and filter fields from JSON alert output with jq.

Paginate an API

Code editor

Fix a script that stops at page one and mishandles a 429 response.

Build a playbook

Diagram

Order triggers, enrichment, decision and containment steps for a phishing alert.

Test a hardening rule

Code editor

Write a test that fails when SSH root login is enabled.

CHECKPOINT (30 min)

Bash and Python security scripting, API handling, SOAR playbook design, safe automation, infra tests

ENG-15

Incident Readiness and Resilience

Intermediate

5 lessons | 4 labs | 4h 25m

- + Write and exercise an incident response plan
- + Design backup and DR to meet RTO and RPO
- + Run purple team exercises to validate controls

LESSONS (15 min each)

- 1 IR plan and roles**
Build an IR plan around NIST SP 800-61 phases with roles, escalation, communications and playbooks.
- 2 Tabletop exercises**
Design injects, run a tabletop and capture gaps as tracked action items.
- 3 Backups and disaster recovery**
Apply 3-2-1-1-0, immutable and offline backups, restore testing and defined RTO/RPO.
- 4 Business continuity and ransomware resilience**
Run a BIA, set dependencies and recovery order and plan for ransomware scenarios.
- 5 Purple team exercises**
Emulate ATT&CK techniques with Atomic Red Team and tune detections from the results.

SIMULATED LABS

Tabletop a ransomware case

Scenario

Respond to timed injects and decide on containment, communication and recovery.

Pick backup strategy

Config editor

Set retention, immutability and test schedules to meet a stated RPO and RTO.

Recovery order

Diagram

Sequence system restoration by dependency after a BIA.

Purple team detection gap

Mock SIEM

Run a simulated technique, find it undetected and write the missing rule.

CHECKPOINT (30 min)

IR plan elements, tabletop value, 3-2-1-1-0 backups, RTO/RPO, BIA, purple team

ENG-16

GRC for Engineers

Intermediate

7 lessons | 5 labs | 5h 35m

- + Perform a risk assessment and map controls to frameworks
- + Explain ISO 27001, SOC 2, PCI DSS and NIST SP 800-53 requirements
- + Collect audit evidence efficiently

LESSONS (15 min each)

- 1 Risk assessment methods**
Compute risk from likelihood and impact, compare qualitative and quantitative (ALE) and set treatment options.
- 2 Policies, standards and control mapping**
Distinguish policy, standard and procedure and map one control to multiple frameworks.
- 3 ISO/IEC 27001**
Explain the ISMS, Annex A controls, the Statement of Applicability and certification audits.
- 4 SOC 2**
Describe the Trust Services Criteria, Type I versus Type II and common control tests.
- 5 PCI DSS**
Explain cardholder data scope, segmentation, key requirements and compensating controls.
- 6 NIST SP 800-53 and CSF**
Use control families, baselines and the CSF functions to structure a program.
- 7 Audits and evidence collection**
Prepare for audits with automated evidence, sampling and handling of findings.

SIMULATED LABS

Score a risk register

Scenario

Rate likelihood and impact for six risks and choose treat, transfer, accept or avoid.

Map controls

Diagram

Link a single control to ISO, SOC 2 and PCI requirements to cut duplicate work.

Define PCI scope

Diagram

Mark systems in, connected to and out of scope for the cardholder data environment.

Gather evidence

File explorer

Pick the right evidence artifacts for five SOC 2 control requests.

Respond to an audit finding

Chat sim

Discuss a finding with the auditor and agree a remediation plan and date.

CHECKPOINT (30 min)

Risk calculation, framework requirements and differences, control mapping, audit evidence

ENG-17

Security Metrics and Program Management

Advanced

3 lessons | 2 labs | 2h 55m

- + Select KPIs that show security outcomes
- + Build a roadmap and budget tied to risk
- + Communicate security status to leadership

LESSONS (15 min each)

1 Security KPIs and KRIs

Choose outcome metrics such as MTTD, MTTR, patch SLA compliance and avoid vanity metrics.

2 Roadmaps and budgets

Prioritize initiatives by risk reduction and cost and justify budget with maturity models.

3 Reporting to leadership

Present risk in business terms, using concise dashboards and clear asks.

SIMULATED LABS

Pick the right KPIs

Scenario

Choose metrics for a board report and discard ones that do not show risk change.

Brief the executive

Chat sim

Answer leadership questions on a breach risk and request budget with a clear impact statement.

CHECKPOINT (30 min)

KPI versus vanity metrics, prioritization and budgeting, business-focused communication

ENG-18

Capstone: Secure a Company

Advanced

3 lessons | 2 labs | 2h 55m

- + Review an architecture for security gaps
- + Prioritize findings into a hardening plan
- + Present a risk-based roadmap

LESSONS (15 min each)

1 Design review of the company

Threat model the fictional company's architecture and list gaps across identity, network, cloud and data.

2 Hardening plan and prioritization

Turn findings into a prioritized plan with owners, effort and quick wins.

3 Roadmap and presentation

Present the plan with metrics, residual risk and a 12-month roadmap.

SIMULATED LABS

Review the architecture

Diagram

Mark weaknesses on a company architecture diagram and tag each by risk.

Build the plan

Scenario

Choose and sequence remediation work under a fixed budget and justify trade-offs.

CHECKPOINT (30 min)

Applying design review, prioritization and communication skills across the full path

AI Security

71h 50m

Understand how AI systems work, how they are attacked and defended, and how to use AI safely in security work.

Best for: Security people, developers and ML engineers working on AI products.

Needs: Security 101. No data science background needed.

Certification link: Supports OWASP LLM Top 10, MITRE ATLAS and NIST AI RMF knowledge; useful context for CompTIA SecAI+ and ISO 42001 study. Guide only.

CAPSTONE: Assess a RAG Support Agent End to End (5h)

Threat model a RAG assistant, probe injection and leakage, inspect the pipeline and agent permissions, map findings to OWASP LLM, and brief a fix plan.

STAGE 1: FOUNDATIONS

AI-01

AI and ML Foundations

Beginner

6 lessons | 4 labs | 4h

- + Distinguish supervised, unsupervised and reinforcement learning
- + Trace data through an ML pipeline from ingestion to deployment
- + Interpret precision, recall and confusion matrices for a model

LESSONS (15 min each)

- Machine learning concepts and paradigms**
Explain supervised, unsupervised, self-supervised and reinforcement learning with security-relevant examples.
- Training versus inference**
Describe training and inference and where each phase exposes data, weights and compute to attack.
- Neural networks: layers, weights, gradients**
Explain neurons, activations, loss functions and backpropagation at a conceptual level.
- Data pipelines and feature engineering**
Map ingestion, labeling, cleaning, splitting and feature stores, and name the trust boundaries in each stage.
- Evaluating models: metrics and overfitting**
Compute accuracy, precision, recall and F1 from a confusion matrix and spot overfitting from train/test gaps.
- Common model types and where they are used**
Match classifiers, regressors, CNNs, RNNs, tree ensembles, GANs and diffusion models to security use cases.

SIMULATED LABS

Read a confusion matrix

Scenario

Given a malware classifier's results, compute precision, recall and F1 and decide if it is fit for blocking.

Draw the ML pipeline trust boundaries

Diagram

Place data source, labeling, training, registry and serving nodes and mark where untrusted input enters.

Spot overfitting in training logs

Log viewer

Read epoch logs of train versus validation loss and identify the epoch where the model begins to overfit.

Run a toy classifier

Terminal

Use scikit-learn commands to train, split and score a spam classifier, then compare two feature sets.

CHECKPOINT (30 min)

Training vs inference, pipeline stages, confusion-matrix metrics, overfitting and model type selection

AI-02

How LLMs Work

Beginner

6 lessons | 4 labs | 4h

+ Explain tokenization, embeddings and attention in plain terms

+ Describe how RAG, fine-tuning and agents extend a base model

+ Predict how context window limits and prompt structure affect output

LESSONS (15 min each)

1 Tokens and tokenization

Explain how BPE tokenizers split text, why token counts drive cost and limits, and cause quirks.

2 Embeddings and vector similarity

Explain embeddings, cosine similarity and vector databases, and why nearest-neighbor search powers retrieval.

3 Transformers and attention, intuitively

Describe self-attention, next-token prediction and sampling parameters (temperature, top-p) without the math.

4 Context windows and prompt structure

Explain system, user and assistant roles, context limits, and how instruction priority is (not) enforced.

5 RAG and fine-tuning

Compare retrieval-augmented generation, fine-tuning and LoRA, and list the data-exposure risks of each.

6 Agents, tools and function calling

Describe the agent loop, function-calling schemas and MCP, and where untrusted text enters the loop.

SIMULATED LABS

Count tokens and estimate cost

Terminal

Run a tokenizer on sample prompts, compare token counts across strings and compute a request cost.

Tune sampling parameters

Chat sim

Adjust temperature and top-p on a sandbox model and record how determinism and risk of odd output change.

Trace a RAG request

Diagram

Order the query, embedding, vector search, prompt assembly and generation steps and tag untrusted data paths.

Review an agent tool schema

Config editor

Read a function-calling JSON schema and identify which parameters accept free text from the model.

CHECKPOINT (30 min)

Tokens, embeddings, attention intuition, context limits, RAG versus fine-tuning, agent loop

AI-03

Threats to AI Systems

Intermediate

5 lessons | 4 labs | 4h 25m

+ Enumerate the attack surface of an AI system end to end

+ Build a threat model for an ML-backed application

+ Map observed attacks to MITRE ATLAS and NIST AI 100-2 categories

LESSONS (15 min each)

1 The AI attack surface

List attack points across data, training, model artifacts, serving APIs, plugins and users.

2 Threat modeling AI systems

Apply STRIDE and data flow diagrams to an ML app, adding model and data-specific threats.

3 MITRE ATLAS tactics and techniques

Navigate ATLAS tactics from reconnaissance to impact and map case studies to technique IDs such as AML.T0051.

4 NIST adversarial ML taxonomy

Use NIST AI 100-2 to classify evasion, poisoning, privacy and abuse attacks by attacker goal and knowledge.

5 Attacker capabilities and risk rating

Rate threats by access level (white, gray, black box), impact and likelihood, and choose mitigations.

SIMULATED LABS

Threat model a chatbot

Diagram

Draw a data flow diagram for a support chatbot and annotate trust boundaries and AI-specific threats.

Map an incident to ATLAS

Scenario

Read a short incident description and select the matching ATLAS tactics and technique IDs in order.

Classify attacks by NIST taxonomy

Scenario

Sort ten attack summaries into evasion, poisoning, privacy or abuse and name attacker knowledge level.

Triage AI findings by risk

Mock SIEM

Review alerts from an inference gateway and rank them by likelihood and impact using the threat model.

CHECKPOINT (30 min)

AI attack surface, STRIDE for ML, ATLAS technique mapping, NIST AI 100-2 classes

STAGE 2: ATTACKS AND DEFENSES

AI-04

Prompt Injection and Jailbreaks

Intermediate

7 lessons | 5 labs | 5h 35m

- + Recognize direct and indirect prompt injection payloads
- + Apply layered guardrails and test them with an evaluation set
- + Measure defense effectiveness with attack success rate

LESSONS (15 min each)

- 1 Direct prompt injection**
Explain how user text overrides instructions and craft benign test payloads for instruction hijacking.
- 2 Indirect prompt injection**
Describe how poisoned web pages, emails and documents inject instructions through retrieved content.
- 3 Jailbreak patterns**
Recognize role-play, encoding, multi-turn escalation and many-shot jailbreaks and why they work.
- 4 Input and output guardrails**
Configure classifiers, allow-lists, delimiters and output filters, and state their known bypass limits.
- 5 Architectural defenses**
Apply privilege separation, dual-LLM patterns, structured outputs and context isolation to limit impact.
- 6 Evaluating defenses**
Build a test set, compute attack success rate and false positive rate, and compare guardrail configurations.
- 7 Tooling: Garak, PyRIT and Promptfoo**
Run automated probes and read their reports to find regressions after prompt or model changes.

SIMULATED LABS

Classify injection attempts

Scenario

Label fifteen prompts as benign, direct injection, indirect injection or jailbreak and justify each.

Hijack a sandbox assistant

Chat sim

Use a harmless canary instruction to override a sandbox system prompt, then document the transcript.

Find the poisoned document

File explorer

Browse a RAG corpus of files and locate the document carrying a hidden instruction payload.

Harden a system prompt and filter

Config editor

Edit delimiters and output filter rules, then rerun the test set to lower attack success rate.

Run a Garak probe

Terminal

Run a garak probe against a mock endpoint and interpret the pass/fail summary per probe.

CHECKPOINT (30 min)

Direct vs indirect injection, jailbreak families, layered defenses, ASR and false positive metrics

AI-05

OWASP Top 10 for LLM Apps

Intermediate

8 lessons | 6 labs | 6h 30m

- + Name and explain each OWASP LLM Top 10 risk
- + Identify vulnerable patterns in LLM application code and config
- + Recommend a control for each risk category

LESSONS (15 min each)

- 1 OWASP LLM Top 10 overview**
Walk through the current list, its risk ranking logic and how it relates to ATLAS and NIST AI RMF.
- 2 LLM01 Prompt injection and LLM05 output handling**
Explain how unvalidated model output reaches shells, SQL, HTML and templates, causing XSS or RCE.
- 3 Sensitive information disclosure**
Describe leakage of secrets, PII and system prompts through training data, context and logs, and mitigations.
- 4 Supply chain risks**
Identify risks in third-party models, datasets and plugins, and verify with hashes and SBOM/AIBOM.
- 5 Data and model poisoning**
Explain how tampered training or fine-tuning data creates integrity failures and how to detect it.
- 6 Excessive agency**
Recognize excessive functionality, permissions and autonomy in agents and apply least privilege and approval.
- 7 System prompt leakage and vector weaknesses**
Assess exposed system prompts and RAG access-control gaps such as cross-tenant retrieval.
- 8 Misinformation and unbounded consumption**
Handle hallucinated output, overreliance and denial-of-wallet with grounding, rate limits and quotas.

SIMULATED LABS

Exploit an output handling flaw

Web proxy

In a sandbox chat app, intercept a response containing script markup and show it executing in the page.

Fix unsafe output code

Code editor

Patch an app that passes model output to eval or a SQL string with encoding and parameterized queries.

Find leaked secrets in logs

Log viewer

Search LLM request logs for API keys, PII and system prompt text and list the exposure paths.

Audit agent permissions

Config editor

Reduce a tool manifest from admin scope to least privilege and add approval for destructive actions.

Check cross-tenant retrieval

Terminal

Query a sandbox vector store with two tenant tokens and prove which one can read the other's documents.

Match risks to controls

Scenario

Match eight application scenarios to the correct OWASP LLM risk and its primary mitigation.

CHECKPOINT (30 min)

OWASP LLM Top 10 risks, vulnerable patterns, excessive agency, disclosure, supply chain controls

AI-06

Data and Model Attacks

Advanced

7 lessons | 5 labs | 6h 25m

- + Describe how poisoning, backdoor and evasion attacks work
- + Explain extraction and privacy attacks and their prerequisites
- + Select defenses suited to each attack class

LESSONS (15 min each)

- 1 Data poisoning**
Explain label flipping and clean-label poisoning, how little data is needed and how to sanitize datasets.
- 2 Backdoors and trojaned models**
Describe trigger-based backdoors, BadNets and sleeper behavior, and detection with Neural Cleanse style tests.
- 3 Adversarial examples and evasion**
Explain FGSM and PGD perturbations, transferability and robustness measures like adversarial training.
- 4 Model extraction and stealing**
Describe query-based cloning, API rate limits, output perturbation and watermarking as countermeasures.
- 5 Membership inference**
Explain how confidence gaps reveal training membership and how regularization and DP reduce it.
- 6 Model inversion and training data extraction**
Describe reconstruction of training samples and LLM memorization extraction attacks.
- 7 Defense selection and trade-offs**
Compare robustness, privacy and accuracy trade-offs and pick controls per threat and attacker access.

SIMULATED LABS

Spot poisoned training samples

File explorer

Inspect a labeled image dataset and flag samples with flipped labels and a repeated trigger patch.

Run FGSM in a sandbox

Terminal

Execute a provided FGSM script on a toy classifier and report the epsilon at which prediction flips.

Detect extraction in API logs

Mock SIEM

Query inference logs for high-volume systematic queries from one key and write a detection rule.

Score membership inference risk

Code editor

Complete a short script comparing confidence on train versus test samples and compute the attack AUC.

Choose defenses per attack

Scenario

Pick rate limiting, DP, adversarial training or data vetting for five described attacks and justify.

CHECKPOINT (30 min)

Poisoning, backdoors, adversarial examples, extraction, membership inference and matching defenses

AI-07

Securing the ML Pipeline

Advanced

6 lessons | 4 labs | 5h 20m

- + Verify provenance and integrity of datasets and models
- + Identify unsafe serialization and scan model files
- + Design access control and drift monitoring for ML pipelines

LESSONS (15 min each)

- 1 Data provenance and lineage**
Track dataset origin, versions and transformations with DVC or hashes and verify trust before training.
- 2 Model registries and access control**
Configure registry roles, stage promotion and separation of duties for training, approval and deployment.
- 3 Model signing and integrity**
Sign and verify model artifacts with Sigstore or cosign and hash-pin dependencies.
- 4 Unsafe serialization: pickle and friends**
Explain how pickle deserialization gives code execution and why safetensors and ONNX reduce the risk.
- 5 Scanning and securing ML supply chain**
Use tools such as picklescan and ModelScan, SBOM and AIBOM, and vet hub downloads.
- 6 Drift monitoring and pipeline observability**
Detect data and concept drift with PSI or KS tests and alert on pipeline tampering and anomalies.

SIMULATED LABS

Inspect a pickle for payloads

Code editor

Disassemble a sandbox pickle file with pickletools and identify the malicious reduce call.

Scan a model hub download

Terminal

Run a model scanner on three artifacts and decide which to quarantine based on the findings.

Verify a signed model

Terminal

Run signature and hash verification commands and explain why one artifact fails verification.

Tighten registry permissions

Config editor

Edit role bindings so training jobs cannot promote models to production without approval.

CHECKPOINT (30 min)

Provenance, signing, pickle risks, scanning tools, registry access control, drift detection

AI-08

Securing AI Agents and Tool Use

Advanced

6 lessons | 4 labs | 5h 20m

- + Apply least privilege and sandboxing to AI agents
- + Assess MCP servers and connectors for risk
- + Design human-in-the-loop approval and secret handling

LESSONS (15 min each)

- 1 Agent architecture and risk model**
Describe planner, memory and tool components and the confused deputy problem in agent systems.
- 2 Least privilege and tool permissions**
Scope tool access with per-tool allow-lists, read-only defaults and short-lived scoped credentials.
- 3 Sandboxing agent execution**
Isolate code execution using containers, seccomp, network egress rules and filesystem limits.
- 4 Connectors and MCP security**
Review MCP servers for tool poisoning, over-broad scopes, rug pulls and unvetted third-party code.
- 5 Human in the loop**
Design approval gates by action risk, avoid approval fatigue and log decisions for audit.
- 6 Secrets and audit logging**
Keep secrets out of prompts and context, use vault references and trace tool calls for forensics.

SIMULATED LABS

Review an MCP tool manifest

Config editor

Find poisoned tool descriptions and excess scopes in an MCP config and remove or restrict them.

Trace an agent incident

Log viewer

Follow an agent's tool call log to find the step where injected text triggered an unauthorized action.

Sandbox an agent runtime

Config editor

Set container egress rules, read-only mounts and resource limits for an agent code tool.

Design approval policy

Scenario

Classify twelve agent actions as auto-approve, require approval or deny and set the policy.

CHECKPOINT (30 min)

Least privilege, sandboxing, MCP and connector risks, approval gates, secret handling

STAGE 3: ASSESS AND GOVERN

AI-09

AI Red Teaming

Advanced

6 lessons | 4 labs | 5h 20m

- + Scope an AI red team engagement with clear rules
- + Run structured and automated probes against a model application
- + Report findings with severity, evidence and remediation

LESSONS (15 min each)

- 1 Scoping and rules of engagement**
Define targets, harm categories, authorization, data handling and stop conditions for an AI red team.
- 2 Test planning and harm taxonomies**
Build a test plan mapped to OWASP LLM, ATLAS and harm categories such as bias, toxicity and misuse.
- 3 Manual adversarial testing**
Apply creative prompts, multi-turn strategies and tool abuse to find failures, and log reproducible steps.
- 4 Automated probing tools**
Use Garak, PyRIT and Promptfoo to generate attacks at scale and tune scoring.
- 5 Safety and robustness evaluations**
Run benchmark-style evaluations, measure refusal and over-refusal rates and interpret metrics.
- 6 Reporting and retesting**
Write findings with severity, reproduction, impact, remediation and verify fixes with regression tests.

SIMULATED LABS

Write a rules of engagement

Config editor

Complete a scope template listing in-scope models, forbidden actions and escalation contacts.

Probe a sandbox chatbot

Chat sim

Execute a planned set of misuse and injection tests and record which succeeded.

Run PyRIT-style automation

Terminal

Launch an automated attack run, then read the scored results and pick top findings to verify manually.

Draft a finding

Scenario

Rate severity and write reproduction steps, impact and fix for a discovered data leak.

CHECKPOINT (30 min)

Scoping, test plan design, automated probing, safety metrics and report quality

AI-10

AI Privacy and Data Protection

Intermediate

4 lessons | 3 labs | 3h 30m

- + Identify privacy risks across the AI data lifecycle
- + Explain differential privacy and federated learning
- + Map AI data handling to GDPR and similar regulations

LESSONS (15 min each)

- 1 Training data privacy and PII leakage**
Describe memorization, PII in datasets and prompts, and controls such as redaction and data minimization.
- 2 Differential privacy and federated learning**
Explain epsilon, noise addition, DP-SGD and federated averaging with their limits and trade-offs.
- 3 Regulations: GDPR, CCPA and consent**
Apply lawful basis, purpose limitation, data subject rights and DPIAs to AI systems.
- 4 Privacy engineering for LLM apps**
Implement PII detection, retention limits, log scrubbing and vendor data processing terms.

SIMULATED LABS

Redact PII before logging

Code editor

Write regex and NER-style rules that mask emails, phone numbers and IDs in prompts, then test on samples.

Find PII in a dataset

File explorer

Browse training files, tag records containing personal data and decide remove, mask or retain.

Run a mini DPIA

Scenario

Answer assessment questions for a customer-chat feature and choose controls for each identified privacy risk.

CHECKPOINT (30 min)

Memorization, PII controls, differential privacy and federated learning basics, GDPR duties

AI-11

AI Governance, Risk and Compliance

Intermediate

5 lessons | 4 labs | 4h 25m

- + Apply NIST AI RMF functions to an AI system
- + Classify a system under the EU AI Act risk tiers
- + Respond to and document an AI incident

LESSONS (15 min each)

- 1 NIST AI RMF: Govern, Map, Measure, Manage**
Apply the four functions and the trustworthiness characteristics to a use case.
- 2 ISO/IEC 42001 AI management system**
Describe the AIMS clauses, Annex A controls and how they fit with ISO 27001.
- 3 EU AI Act risk tiers and obligations**
Classify prohibited, high-risk, limited-risk and minimal-risk systems and list provider duties.
- 4 Model cards, documentation and responsible AI**
Write model cards and datasheets covering intended use, limits, bias results and monitoring.
- 5 AI incident handling**
Adapt incident response to model failures, harmful outputs and data leaks, with reporting and lessons learned.

SIMULATED LABS

Classify under the EU AI Act

Scenario

Sort six described systems into EU AI Act risk tiers and list the obligations that apply.

Complete a model card

Config editor

Fill in intended use, training data, evaluation results and limitations fields for a sample model.

Map controls to NIST AI RMF

Diagram

Place risk controls under Govern, Map, Measure and Manage for a hiring-screen model.

Triage an AI incident

Chat sim

Work through a harmful-output report by choosing containment, evidence collection and notification steps.

CHECKPOINT (30 min)

AI RMF functions, ISO 42001 structure, EU AI Act tiers, documentation and incident response

STAGE 4: AI AND THE DEFENDER

AI-12

AI for Defenders

Intermediate

6 lessons | 4 labs | 4h 40m

- + Use AI to speed up SOC triage and summaries safely
- + Evaluate AI detection and anomaly tools with real metrics
- + Spot and handle hallucinated security output

LESSONS (15 min each)

- 1 AI in the SOC: triage and summarization**
Apply LLMs to alert enrichment, case summaries and query drafting with human validation.
- 2 AI-assisted detection engineering**
Generate and validate Sigma or KQL rules with AI, testing against sample logs before deployment.
- 3 Phishing detection with ML**
Describe feature-based and language-model phishing classifiers and their evasion weaknesses.
- 4 Anomaly detection basics**
Explain baselines, isolation forests and UEBA scoring, and manage false positives.
- 5 Hallucination risks in security work**
Identify fabricated CVEs, commands and indicators and apply verification habits.
- 6 Judging AI security tools**
Evaluate vendor claims using precision, recall, data handling, explainability and pilot results.

SIMULATED LABS

Triage alerts with AI summaries

Mock SIEM

Review AI-generated summaries of five alerts, verify them against raw events and mark which are wrong.

Validate an AI-written detection

Code editor

Test a generated Sigma rule against sample logs, fix a logic error and reduce false positives.

Catch a hallucinated IOC

Chat sim

Question an AI assistant's report and verify each CVE and hash, flagging the fabricated ones.

Score a vendor tool

Scenario

Compare two AI detection products on supplied metrics and choose one with written justification.

CHECKPOINT (30 min)

AI in SOC workflows, detection validation, anomaly basics, hallucination checks, tool evaluation

AI-13

AI-Enabled Threats

Intermediate

5 lessons | 4 labs | 4h 25m

- + Recognize deepfake and voice-clone fraud techniques
- + Identify AI-written phishing and automated attack traits
- + Apply layered detection and organizational defenses

LESSONS (15 min each)

- 1 Deepfakes and synthetic media**
Explain how face and video synthesis works and list visual and metadata cues of manipulation.
- 2 Voice cloning and vishing**
Describe cloning from short samples, CEO-fraud scenarios and callback or code-word verification.
- 3 AI-written phishing and social engineering**
Compare LLM-generated lures with traditional ones and adjust email controls and training.
- 4 Automated attacks and AI-assisted malware**
Describe automated recon, exploit generation and polymorphism, and what defenders should expect.
- 5 Detection and organizational defenses**
Apply C2PA provenance, liveness checks, out-of-band verification and payment approval controls.

SIMULATED LABS

Verify a suspicious voice request

Scenario

Handle a cloned-voice payment request by choosing verification steps and escalation.

Analyze a phishing email set

Packet viewer

Inspect headers and body of eight emails and decide which look AI-generated and which authentication checks fail.

Inspect media metadata

Terminal

Run exiftool and C2PA verification on sample files and judge authenticity from the output.

Hunt automated login abuse

Mock SIEM

Query authentication logs for high-speed credential attempts and write a rate-based detection.

CHECKPOINT (30 min)

Deepfakes, voice cloning, AI phishing traits, automated attacks and verification controls

AI-14

Capstone: Assess an AI App

Advanced

3 lessons | 2 labs | 2h 55m

- + Perform a structured security review of an LLM application
- + Prioritize findings and map them to standard frameworks
- + Present remediation guidance to stakeholders

LESSONS (15 min each)

- 1 Scope and threat model the target app**
Document architecture, data flows, models and tools of the fictional app and identify the top threats.
- 2 Test and evidence the findings**
Probe for injection, leakage, excessive agency and supply chain flaws and collect reproducible evidence.
- 3 Report, prioritize and remediate**
Map findings to OWASP LLM and NIST AI RMF, rate severity and write a prioritized fix plan.

SIMULATED LABS

Threat model the target app

Diagram

Diagram the app's components and annotate five prioritized AI-specific threats.

Assess and report the app

Scenario

Review config, logs and chat transcripts, record findings with evidence and rank them by severity.

CHECKPOINT (30 min)

End-to-end AI app review: threat model, evidence quality, severity ranking and remediation plan